

UNIVERSIDAD INDOAMÉRICA

FACULTAD DE INGENIERÍAS

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

TEMA:

METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES

Trabajo de Titulación modalidad Trabajo de Integración Curricular

Autor

Ramon Alejandro Manzaba Castro

Tutora

Ing. Cristina Jiménez, MSc.

QUITO – ECUADOR

2026

AUTORIZACIÓN POR PARTE DEL AUTOR PARA LA CONSULTA, REPRODUCCIÓN PARCIAL O TOTAL, Y PUBLICACIÓN ELECTRÓNICA DEL TRABAJO DE INTEGRACIÓN CURRICULAR

Yo, Ramon Alejandro Manzaba Castro, declaro ser autor del Trabajo de Titulación con el nombre "Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales", como requisito para optar al grado de Ingeniero en Tecnologías de la Información y autorizo al Sistema de Bibliotecas de la Universidad Tecnológica Indoamérica para que, con fines netamente académicos, divulgue esta obra a través del Repositorio Digital Institucional (RDI-UTI).

Los usuarios del RDI-UTI podrán consultar el contenido de este trabajo en las redes de información del país y del exterior, con las cuales la Universidad tenga convenios. La Universidad Tecnológica Indoamérica no se hace responsable por el plagio o copia del contenido parcial o total de este trabajo.

Del mismo modo, acepto que los Derechos de Autor, Morales y Patrimoniales sobre esta obra serán compartidos entre mi persona y la Universidad Tecnológica Indoamérica, y que no tramitaré la publicación de este trabajo en ningún otro medio sin autorización expresa de la misma. En caso de que exista el potencial de generación de beneficios económicos o patentes, producto de este trabajo, acepto que se deberán firmar convenios específicos adicionales donde se acuerden los términos de adjudicación de dichos beneficios.

Para constancia de esta autorización, en Quito, Ecuador, a los xx días del mes de xx de 2026, firmo conforme:

Autor: Ramon Alejandro Manzaba Castro

Firma:

Número de Cédula: 1729303998
Dirección: Provincia, Quito, Quitumbe, San Martin de porres
Correo Electrónico: ramonalejandromanzaba@gmail.com
Teléfono: 0989224684

APROBACIÓN DE LA TUTORA

En mi calidad de Tutora del Trabajo de Titulación "METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES", presentado por Ramon Alejandro Manzaba Castro, para optar por el Título de Ingeniero en Tecnologías de la Información.

CERTIFICO

Que dicho Trabajo de Titulación ha sido revisado en todas sus partes y considero que reúne los requisitos y méritos suficientes para ser sometido a la presentación pública y evaluación por parte del Tribunal revisor que se designe.

Quito, Ecuador, xx de xx de 2026

Ing. Cristina Jiménez, MSc.

DECLARACIÓN DE AUTENTICIDAD

Yo, Ramon Alejandro Manzaba Castro, declaro que los contenidos y los resultados obtenidos en el presente Trabajo de Titulación "Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales", como requerimiento previo para la obtención del Título de Ingeniero en Tecnologías de la Información, son absolutamente originales, auténticos y personales y de exclusiva responsabilidad legal y académica del autor.

Quito, Ecuador, xx de xx de 2026

Ramon Alejandro Manzaba Castro
(Número de cédula)

APROBACIÓN DE LECTORES

El Trabajo de Titulación ha sido revisado, aprobado y autorizada su impresión y empastado sobre el tema "METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES", presentado por Ramon Alejandro Manzaba Castro, previo a la obtención del Título de Ingeniero en Tecnologías de la Información, y reúne los requisitos de fondo y forma para su sustentación.

Quito, Ecuador, xx de xx de 2026

Ing. Andrés Rubio Proaño, PhD.
LECTOR

Ing. Jaime Fabrizzio Peñafiel, MSc.
LECTOR

DEDICATORIA

(Obligatoria)
La dedicatoria va en la parte inferior derecha de la página.

AGRADECIMIENTO

(Obligatorio)
El agradecimiento va en la parte inferior derecha de la página.

Índice de Contenidos

CAPÍTULO I: Introducción **18**

1.1 Contextualización 18

1.1.1 Contexto macro: la exposición del sector educativo a nivel mundial 18

1.1.2 Contexto meso: América Latina y Ecuador 19

1.1.3 Contexto micro: las IES ecuatorianas y la unidad de análisis 21

1.2 Estado del Arte 22

1.2.1 Marcos de referencia para la evaluación de impacto y el riesgo de privacidad 22

1.2.2 Métodos de estimación del riesgo 25

1.2.3 Gestión de riesgos de seguridad de la información en el sector público y educativo 26

1.2.4 Protección de datos personales en instituciones de educación superior 26

1.2.5 Antecedentes latinoamericanos y ecuatorianos 27

1.2.6 Análisis comparativo y brecha identificada 28

1.3 Planteamiento del Problema 29

1.3.1 Análisis crítico 29

1.3.2 Prognosis 31

1.3.3 Formulación del problema 31

1.3.4 Preguntas directrices 31

1.3.5 Delimitación 31

1.4 Justificación 32

1.5 Objetivos 33

1.5.1 Objetivo General 33

1.5.2 Objetivos Específicos 33

1.6 Alcance del Proyecto 34

1.7 Fundamentación Teórica 35

CAPÍTULO II: Metodología **36**

2.1 Diagnóstico de la Situación Actual 36
2.1.1 Caracterización del caso simulado 36
2.1.2 Descripción del proceso de admisión y matrícula 36
2.1.3 Limitaciones de la situación actual 38
2.2 Área de Estudio 39
2.3 Metodología de Desarrollo o Implementación 41
2.3.1 Enfoque y tipo de investigación 41
2.3.2 Ciencia del diseño como marco metodológico 41
2.3.3 Unidad de análisis, población y muestra 41
2.4 Técnicas e Instrumentos de Recolección de Información 42
2.4.1 Método Delphi y calibración de las estimaciones 42
2.4.2 Consideraciones éticas 44
2.5 Requerimientos del Proyecto 44
2.5.1 Requerimientos Funcionales 45
2.5.2 Requerimientos No Funcionales 45
2.6 Diseño de la Solución 46
2.6.1 Estructura general de la metodología 46
2.6.2 Modelo de estimación del riesgo 46
2.6.3 Determinación del nivel de riesgo y criterios de aceptación . 48
2.6.4 Estructura de la matriz de riesgos 50
2.7 Justificación Técnica 50

CAPÍTULO III: Implementación, Pruebas y Resultados 52
3.1 Descripción de la Solución 52
3.2 Proceso de Implementación 53
3.2.1 Fase 0: diagnóstico de madurez 53
3.2.2 Fase 1: identificación 54
3.2.3 Fase 2: evaluación 55
3.2.4 Fase 3: mitigación 57
3.2.5 Fase 4: monitoreo 59
3.3 Pruebas y Validación 59
3.3.1 Verificación de la plantilla de matriz 59
3.3.2 Verificación del cumplimiento de los requisitos 60
3.3.3 Validación con expertos 61
3.4 Resultados 61
3.5 Cronograma y Presupuesto 62
3.5.1 Cronograma 62
3.5.2 Presupuesto 62

CAPÍTULO IV: Conclusiones y Recomendaciones **64**
4.1 Conclusiones 64
4.2 Recomendaciones 64
4.3 Trabajos Futuros 64

REFERENCIAS **65**

GLOSARIO **72**

ANEXO A: Lista de verificación de requisitos normativos **73**

ANEXO B: Guía de entrevista semiestructurada **76**

ANEXO C: Cuestionario de madurez en protección de datos personales **78**

ANEXO D: Cuestionario Delphi de estimación de riesgos **80**

ANEXO E: Afirmaciones de calibración de expertos **82**

ANEXO F: Instrumento de validación por juicio de expertos **83**

ANEXO G: Consentimiento informado **85**

ANEXO H: Plantilla de matriz de riesgos **87**

Índice de Tablas

1 Trabajos relacionados con los marcos, la estimación y la gestión de riesgos (ejes 1 a 3). 23
2 Trabajos relacionados con la protección de datos personales en IES y antecedentes regionales (ejes 4 y 5). 24
3 Comparación de marcos y trabajos relacionados con los requisitos del proyecto. 28
4 Árbol de problemas: causas, problema central y efectos. 29

5 Parámetros del caso simulado (IES-S). 37
6 Subprocesos del proceso de admisión y matrícula en la IES-S. . . . 38
7 Área de estudio. 40
8 Relación entre las actividades DSR, las fases de la investigación y los objetivos específicos. 42
9 Técnicas e instrumentos de recolección de información. 43
10 Requisitos funcionales de la metodología. 45
11 Requisitos no funcionales de la metodología. 46
12 Fases, actividades y productos de la metodología. 47
13 Escala de probabilidad (lapso anual). 48
14 Escala de impacto sobre el titular. 49
15 Tabla de decisión del nivel de riesgo. 49
16 Bloques de campos de la matriz de riesgos. 50

17 Nivel de madurez por dominio en la IES-S (caso simulado). 53
18 Registro de actividades de tratamiento (RAT) preliminar del proceso de admisión y matrícula. 54
19 Escenarios de riesgo identificados en el proceso de admisión y matrícula. 55
20 Riesgo inherente de los escenarios del caso simulado. 56
21 Síntesis de la EIPD del subproceso de becas y aranceles diferenciados (SP3). 57
22 Plan de tratamiento y riesgo residual proyectado. 58

23 Indicadores de monitoreo del riesgo. 59
24 Casos de prueba de las reglas de decisión de la plantilla. 60
25 Verificación de los requisitos funcionales en el caso simulado. . . . 60
26 Comparación de la situación inicial y la proyectada en el caso simulado. 61
27 Presupuesto referencial del proyecto (USD). 63

28 Hojas de la plantilla de matriz de riesgos. 87

Índice de Figuras

1 Árbol de problemas. 30

2 Estructura de la metodología propuesta. 47

3 Mapas de calor del riesgo inherente y residual del caso simulado. . . 56

4 Cronograma del proyecto. 62

Índice de Imágenes

Índice de Ecuaciones

1 Puntaje de Brier para la calibración de estimaciones 44
2 Reducción porcentual de escenarios de nivel alto o muy alto 61

Índice de Anexos

Anexo A: Lista de verificación de requisitos normativos 73
Anexo B: Guía de entrevista semiestructurada 76
Anexo C: Cuestionario de madurez en protección de datos personales . . . 78
Anexo D: Cuestionario Delphi de estimación de riesgos 80
Anexo E: Afirmaciones de calibración de expertos 82
Anexo F: Instrumento de validación por juicio de expertos 83
Anexo G: Consentimiento informado 85
Anexo H: Plantilla de matriz de riesgos 87

UNIVERSIDAD INDOAMÉRICA

FACULTAD DE INGENIERÍAS

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

TEMA: METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES

AUTOR(A): Ramon Alejandro Manzaba Castro

TUTOR(A): Ing. Cristina Jiménez, MSc.

RESUMEN EJECUTIVO

[Redacte el resumen del Trabajo de Integración Curricular en un solo párrafo, con un máximo de 300 palabras. Exponga de manera clara el problema, el objetivo general, la metodología empleada, los principales resultados obtenidos y las conclusiones.]

DESCRIPTORES: *[Incluya de 3 a 4 palabras clave representativas, ordenadas alfabéticamente y separadas por comas.]*

UNIVERSIDAD INDOAMÉRICA

FACULTY OF ENGINEERING

BACHELOR'S DEGREE IN INFORMATION TECHNOLOGY ENGINEERING

TOPIC: METHODOLOGY FOR RISK DIAGNOSIS AND MANAGEMENT IN PERSONAL DATA PROCESSING

AUTHOR: Ramon Alejandro Manzaba Castro

ADVISOR: Ing. Cristina Jiménez, MSc.

ABSTRACT

[Write the English version of the executive summary in a single paragraph, with a maximum of 300 words. Clearly present the problem, general objective, methodology, main results, and conclusions.]

KEYWORDS: *[Include 3 to 4 representative keywords in alphabetical order, separated by commas.]*

CAPÍTULO I

INTRODUCCIÓN

El presente trabajo de integración curricular aborda el tema *Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales*, circunscrito a los datos personales de estudiantes y docentes que tratan las instituciones de educación superior (IES) ecuatorianas en el marco de la Ley Orgánica de Protección de Datos Personales (LOPDP).

1.1 Contextualización

1.1.1 Contexto macro: la exposición del sector educativo a nivel mundial

La educación superior se ha consolidado como uno de los sectores con mayor exposición a incidentes que comprometen datos personales. La edición 2024 del estudio *The State of Ransomware in Education*, basada en una encuesta a 5 000 responsables de tecnología de 14 países, de los cuales 600 pertenecían a organizaciones educativas, reportó que el 66 % de las IES había sufrido un ataque de *ransomware* en el último año, que el 77 % de esos ataques terminó con el cifrado de datos y que el costo medio de recuperación en el subsector alcanzó 4,02 millones de dólares [1]. Estas cifras ubican a las universidades por encima del promedio intersectorial y muestran que el problema no se limita a la disponibilidad de los sistemas, sino que afecta de forma directa la confidencialidad de los registros de estudiantes y docentes.

La literatura académica coincide en ese diagnóstico. La revisión de Ulven y Wangen [2] sintetizó los activos críticos, eventos de amenaza y vulnerabilidades frecuentes en la educación superior, concluyó en nueve riesgos estratégicos de ciberseguridad para el sector y advirtió que ya se han producido brechas de datos graves que probablemente se repetirán sin una gestión de riesgos adecuada; los autores señalan, además, que la investigación empírica sobre riesgos en este sector es escasa y presenta vacíos importantes. En la misma línea, Li et al. [3] partieron de que los entornos digitales universitarios, complejos y dinámicos, son altamente vulnerables a brechas de datos y, con una muestra de universidades chinas, encontraron que la divulgación pública de vulnerabilidades incrementa la frecuencia de brechas, mientras que la adopción de servicios en la nube la reduce; es decir, la ex-

posición depende de decisiones de gestión sobre vulnerabilidades y plataformas, lo que refuerza la necesidad de un enfoque de gestión de riesgos y no solo de controles técnicos puntuales.

El crecimiento de las plataformas digitales de aprendizaje amplía la superficie de tratamiento. Liu y Khalil [4], en una revisión sistemática sobre analítica del aprendizaje, identificaron ocho problemas interrelacionados de privacidad y protección de datos a lo largo del ciclo de vida de esos datos, desde la recolección hasta la explotación de resultados. Por su parte, Fernandes et al. [5] estudiaron la implementación del Reglamento General de Protección de Datos (RGPD) en universidades públicas portuguesas y determinaron dieciséis factores críticos de éxito, entre los que destacan el compromiso de la alta dirección y la cultura organizacional de protección de datos; su hallazgo sugiere que, incluso en jurisdicciones con larga tradición normativa, la adecuación de las IES depende más de la gestión que de la tecnología disponible.

1.1.2 Contexto meso: América Latina y Ecuador

En América Latina, los incidentes en universidades han pasado de ser casos aislados a eventos con consecuencias públicas visibles. En marzo de 2023, la Universidad Nacional de Colombia sufrió un ataque de *ransomware* que cifró parte de su información y obligó a aislar sus sistemas financiero, académico y de talento humano mientras se restablecían los servicios [6]. En octubre de 2024, la Universidad Técnica Federico Santa María, en Chile, registró un incidente atribuido al grupo RansomHub, tras el cual se publicaron en la *dark web* alrededor de 14 GB de información que incluía listados de estudiantes con su número de identificación, carrera y año de ingreso, así como datos de deudores del fondo de crédito estudiantil [7]. En el ámbito académico, Zappelini et al. [8] mostraron que, en Brasil, el uso de medios digitales para la docencia y la evaluación remota en IES plantea riesgos específicos cuando los titulares son adolescentes, situación análoga al régimen de categorías especiales que establece la normativa ecuatoriana.

Ecuador cuenta con un antecedente nacional que evidenció la magnitud del problema antes de la existencia de una ley específica. En septiembre de 2019 se reportó la exposición de una base de datos de una empresa privada de mercadeo y analítica que contenía información de alrededor de 20 millones de personas, incluidos cerca de 6,7 millones de niños, con campos como nombres, fecha de nacimiento, domicilio, teléfonos y nivel de educación [9]. Ese caso aceleró el debate legislativo que culminó con la expedición de la LOPDP, publicada en el Quinto Suplemento del Registro Oficial N.º 459 el 26 de mayo de 2021 [10]. Su reglamento

general fue expedido mediante el Decreto Ejecutivo N.º 904 y publicado en el Tercer Suplemento del Registro Oficial N.º 435 el 13 de noviembre de 2023 [11].

La LOPDP establece obligaciones que inciden directamente en la gestión de riesgos. El artículo 37 exige al responsable identificar la probabilidad de riesgos e implementar un proceso de verificación, evaluación y valoración continua de las medidas de seguridad; el artículo 40 obliga a utilizar una metodología de análisis de riesgos, amenazas y vulnerabilidades que considere las particularidades del tratamiento, de las partes involucradas y las categorías y volumen de datos; y el artículo 42 vuelve obligatoria la evaluación de impacto cuando exista tratamiento a gran escala de categorías especiales de datos [10, arts. 37, 40 y 42]. A ello se suma la obligación de notificar las vulneraciones de seguridad a la autoridad en el término de cinco días (art. 43). La Disposición Transitoria Primera difirió por dos años la vigencia del régimen sancionatorio, con lo que el periodo de adecuación concluyó en 2023 [10].

La Superintendencia de Protección de Datos Personales (SPDP) comenzó a emitir normativa técnica entre 2025 y 2026. Mediante la Resolución N.º SPDP-SPD-2025-0003-R, del 29 de abril de 2025, publicada en el Cuarto Suplemento del Registro Oficial N.º 41 el 19 de mayo de 2025, expidió la *Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales*, cuyo capítulo I es de cumplimiento obligatorio y cuyo capítulo II ofrece metodologías referenciales [12, 13]; posteriormente, mediante la Resolución N.º SPDP-SPD-2026-0012-R, publicada en el Suplemento del Registro Oficial N.º 254 el 30 de marzo de 2026, expidió la segunda versión (V.2) de la guía [14]. Asimismo, la Resolución N.º SPDP-SPD-2026-0005-R, publicada en el Suplemento del Registro Oficial N.º 231 el 25 de febrero de 2026, definió el Modelo Técnico de Gran Escala y estableció que constituyen tratamiento a gran escala, de forma directa, los tratamientos relativos a la salud y a otras categorías especiales, así como el tratamiento sistemático de datos de niñas, niños y adolescentes en entornos educativos; esa calificación vuelve obligatorias la evaluación de impacto previa y la designación de un delegado de protección de datos [15, arts. 12 y 14].

La autoridad ya ha ejercido su potestad sancionadora. El 1 de diciembre de 2025 se dieron a conocer las primeras sanciones por infracciones graves de la LOPDP, impuestas a la Liga Profesional de Fútbol del Ecuador y a la Federación Ecuatoriana de Fútbol por un total cercano a 454 500 dólares, con fundamento en el artículo 68 de la ley y por no implementar medidas administrativas, técnicas y físicas suficientes para garantizar un tratamiento adecuado [16, 17]. Aunque ninguno de esos casos corresponde a una IES, demuestran que las obligaciones de la ley son exigibles.

Debe subrayarse, además, que el mismo artículo 68 tipifica como infracción grave del responsable, en su numeral 4, no utilizar metodologías de análisis y gestión de riesgos adaptadas a la naturaleza de los datos personales, a las particularidades del tratamiento y a las partes involucradas [10, art. 68], de modo que la ausencia de una metodología constituye, por sí misma, una conducta sancionable. La aplicación de este régimen es reciente: hasta septiembre de 2025 la SPDP había recibido 191 denuncias sin haber impuesto sanción alguna, porque la ley prevé que ante una infracción grave se ordenen primero medidas correctivas y solo se sancione si estas no se cumplen [18]. En las fuentes públicas consultadas no se identificó, a la fecha de redacción, un procedimiento sancionador contra una IES, por lo que para estas instituciones el riesgo jurídico se mantiene latente y aún no se ha materializado.

1.1.3 Contexto micro: las IES ecuatorianas y la unidad de análisis

En el sistema de educación superior ecuatoriano, la evidencia disponible indica que la adecuación a la LOPDP es heterogénea. Álvarez-Carrión y Hernández-Sotomayor [19] analizaron la protección de datos en plataformas educativas digitales y concluyeron que, aunque la ley ofrece un marco sólido, su implementación enfrenta brechas de infraestructura y de capacitación en ciberseguridad; al revisar vulneraciones documentadas en universidades del país, identificaron los fallos técnicos y el error humano como causas principales. Piray Rodríguez et al. [20], mediante revisión documental y análisis normativo, encontraron diferencias marcadas entre instituciones en la adopción de políticas internas de protección de datos y observaron que solo un número limitado de universidades las aplica de manera destacada. A nivel de gestión de riesgos, López-Vasco et al. [21] documentaron la aplicación de ISO/IEC 27001 en institutos tecnológicos de educación superior del Ecuador, lo que constituye un antecedente de diagnóstico y planificación de controles en el sector, aunque centrado en la seguridad de la información y no en los derechos de los titulares.

La unidad de análisis de este trabajo se ubica en la Universidad Tecnológica Indoamérica (UTI), institución de educación superior particular con sede en Quito, cuya Facultad de Ingenierías propone el presente tema. Las IES tratan datos de estudiantes, aspirantes, graduados, docentes y personal administrativo en procesos como admisión y matrícula, registro de calificaciones, becas, bienestar estudiantil, aula virtual y titulación; varios de esos procesos involucran categorías especiales en los términos del artículo 25 de la LOPDP, como datos de salud, de discapacidad o de adolescentes que ingresan a la universidad [10, art. 25]. La unidad o proceso específico que servirá de caso de estudio se definirá con la tutoría, y toda información

institucional se tratará de forma anonimizada o agregada, sin datos personales reales ni identificación de funcionarios.

1.2 Estado del Arte

La revisión de antecedentes se realizó en bases de datos académicas (IEEE Xplore, ScienceDirect, SpringerLink, Scopus, SciELO y Google Académico) y en los sitios oficiales de autoridades de protección de datos y de organismos de normalización. Se priorizaron publicaciones de 2019 en adelante, sin excluir los trabajos seminales, y solo se incluyeron fuentes con DOI o con publicación oficial verificable. Los criterios de inclusión fueron tres: que el trabajo propusiera o evaluara un método de gestión de riesgos o de evaluación de impacto sobre datos personales, que abordara el tratamiento de datos en instituciones de educación superior, o que aportara evidencia normativa o empírica del contexto latinoamericano y ecuatoriano. Los trabajos seleccionados se organizaron en cinco ejes: (1) marcos de referencia para la evaluación de impacto y el riesgo de privacidad; (2) métodos de estimación del riesgo; (3) gestión de riesgos de seguridad de la información en el sector público y educativo; (4) protección de datos personales en IES, y (5) antecedentes latinoamericanos y ecuatorianos. Las Tablas 1 y 2 resumen los trabajos académicos analizados y la Tabla 3 compara los principales marcos metodológicos con los requisitos de este proyecto.

1.2.1 Marcos de referencia para la evaluación de impacto y el riesgo de privacidad

Los marcos normativos y de autoridades de control constituyen el primer referente para cualquier metodología. La norma ISO/IEC 29134:2023 ofrece directrices para el proceso de evaluación de impacto en la privacidad y para la estructura y el contenido del informe resultante, aplicables a organizaciones de cualquier tipo y tamaño [36]. En el ámbito iberoamericano, la Agencia Española de Protección de Datos (AEPD) publicó en 2021 una guía que unifica la gestión del riesgo y la evaluación de impacto, aplicable a cualquier tratamiento con independencia de su nivel de riesgo y que, para los tratamientos de alto riesgo, orienta la realización de la EIPD y la eventual consulta previa a la autoridad [37]. El NIST Privacy Framework, por su parte, es una herramienta voluntaria basada en riesgos y resultados, organizada en un núcleo, perfiles y niveles de implementación, que no está ligada a un sector ni a una jurisdicción concretos [38]. Para la valoración del impacto de una vulneración, ENISA propuso una metodología de severidad que combina el contexto

Tabla 1: Trabajos relacionados con los marcos, la estimación y la gestión de riesgos (ejes 1 a 3).

Eje	Trabajo	Enfoque y aporte	Limitación respecto de este proyecto
1	Deng et al. [22]	Marco LINDDUN de modelado de amenazas a la privacidad con siete categorías y árboles de amenaza.	Orientado al diseño de software; no estima probabilidad ni impacto.
1	Bieker et al. [23]	Proceso adaptable de EIPD derivado de los requisitos del RGPD.	Marco europeo; sin aplicación sectorial.
1	Vemou y Karyda [24]	Comparación de métodos PIA de autoridades, normas y academia; criterios de buenas prácticas.	Criterios generales, sin aplicación a un caso.
1	Wairimu et al. [25]	Revisión sistemática de metodologías PIA y PRA y de la forma en que se han evaluado.	No se centra en un sector ni en la normativa ecuatoriana.
1	Iwaya et al. [26]	*Scoping review* sobre la aplicación práctica de las PIA/EIPD, sus beneficios y dificultades.	Evidencia mayoritariamente europea; no aborda IES.
1	Wairimu et al. [27]	Percepción de profesionales sobre el uso de categorías de daño a la privacidad en la evaluación de riesgos.	No propone escalas de impacto aplicables a un sector.
2	Wang et al. [28]	Implementación del modelo FAIR mediante redes bayesianas para estimar frecuencia y magnitud de pérdidas.	Perspectiva financiera del responsable; no considera el daño a titulares.
3	Patiño et al. [29]	Metodología de gestión de riesgos TIC basada en ISO/IEC 27005 para entidades gubernamentales ecuatorianas.	Orientada a activos de información, no a derechos de titulares.
3	Ulven y Wangen [2]	Revisión sistemática de riesgos de ciberseguridad en educación superior; nueve riesgos estratégicos.	Identifica riesgos, pero no define un proceso de gestión.
3	Li et al. [3]	Factores que explican las brechas de datos en universidades chinas.	Análisis explicativo; no ofrece una metodología.
3	López-Vasco et al. [21]	Diagnóstico y plan de controles ISO/IEC 27001 en institutos tecnológicos de Ecuador.	Enfoque de seguridad de la información; no integra la LOPDP.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia a partir de las fuentes citadas

Tabla 2: Trabajos relacionados con la protección de datos personales en IES y antecedentes regionales (ejes 4 y 5).

Eje	Trabajo	Enfoque y aporte	Limitación respecto de este proyecto
4	Gursoy et al. [30]	Técnicas de anonimización y privacidad diferencial para analítica del aprendizaje.	Controles técnicos aislados de un proceso de riesgos.
4	Habbabeh et al. [31]	Instrumento de 44 controles para medir la alineación de una IES con el RGPD.	Mide cumplimiento, no riesgo; no distingue riesgo inherente y residual.
4	Vanezi et al. [32]	Cumplimiento del RGPD desde el diseño en una plataforma de *e-learning*.	Limitado a una plataforma; no abarca la institución.
4	Tsai et al. [33]	Expectativas y conductas de privacidad de estudiantes frente a la analítica del aprendizaje.	Estudio de percepción; no evalúa riesgos.
4	Fernandes et al. [5]	Factores críticos de éxito para implementar el RGPD en universidades públicas.	Marco europeo; no propone una metodología de riesgos.
4	Liu y Khalil [4]	Revisión sistemática de problemas de privacidad en el ciclo de vida de la analítica del aprendizaje.	Catálogo de problemas, sin valoración del riesgo.
4	Maguraushe et al. [34]	Encuesta diagnóstica de conciencia, expectativas y confianza de estudiantes sobre privacidad.	Diagnóstico de percepción; no cubre procesos ni controles.
5	Guerrero Argote [35]	Adopción de *e-proctoring* y riesgos para la privacidad en universidades de Argentina, Chile y Perú.	Estudio exploratorio; análisis jurídico preliminar.
5	Zappelini et al. [8]	Datos de adolescentes en IES brasileñas bajo la LGPD; docencia y evaluación remota.	Análisis jurídico; sin método de riesgos.
5	Álvarez-Carrión y Hernández-Sotomayor [19]	Protección de datos en plataformas educativas de IES ecuatorianas.	Diagnóstico normativo; no define un proceso de gestión de riesgos.
5	Piray Rodríguez et al. [20]	Garantías de privacidad y políticas internas en IES ecuatorianas.	Revisión documental; sin aplicación de un método de riesgos.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia a partir de las fuentes citadas

del tratamiento, la facilidad de identificación de los titulares y las circunstancias de la vulneración [39], criterios que resultan útiles para graduar el impacto sobre los titulares.

Desde la academia, LINDDUN aporta un marco sistemático para identificar amenazas a la privacidad a partir de un modelo de flujos de información del sistema, con siete categorías —vinculabilidad, identificabilidad, no repudio, detectabilidad, divulgación de información, desconocimiento e incumplimiento— y catálogos de árboles de amenaza asociados a tecnologías de mejora de la privacidad [22]. Bieker et al. [23] analizaron las disposiciones del RGPD sobre la EIPD y propusieron un proceso adaptable que integra los requisitos ya establecidos con los nuevos de la regulación. Las revisiones posteriores matizan la madurez de este campo: Wairimu et al. [25] muestran que existe una amplia variedad de metodologías PIA y PRA, pero que su validación empírica es limitada y heterogénea, lo que dificulta elegir una de ellas sin adaptación; Iwaya et al. [26], tras sintetizar 45 estudios sobre evaluaciones de impacto aplicadas en organizaciones reales, constatan que aún falta evidencia empírica sobre su adopción y efectividad; y Vemou y Karyda [24] proponen criterios para valorar la calidad de un método PIA, útiles como referencia para evaluar la metodología que este trabajo diseñe. Finalmente, Wairimu et al. [27] concluyen que las categorías de daño a la privacidad son un complemento crítico de las metodologías PIA, EIPD y PRA, aunque recomiendan priorizarlas para distribuir adecuadamente el tiempo y los recursos de la evaluación; este hallazgo respalda la definición de escalas de impacto centradas en el titular.

1.2.2 Métodos de estimación del riesgo

La forma de estimar la probabilidad y el impacto es uno de los puntos más débiles de las metodologías de uso corriente. La mayoría de marcos emplea escalas ordinales y matrices de calor, mientras que los enfoques cuantitativos, como el modelo FAIR, estiman la frecuencia y la magnitud de las pérdidas; Wang et al. [28] implementaron y ampliaron FAIR mediante redes bayesianas, lo que permite incorporar dependencias causales y actualizar las estimaciones con nueva evidencia. La segunda versión de la guía de la SPDP recoge esta discusión y fija reglas que condicionan el diseño de la metodología: toda estimación de probabilidad o impacto debe acompañarse de su justificación (*rationale*); una escala de 1 a 3 o de 1 a 5 no constituye un análisis cuantitativo, sino un conjunto de etiquetas; las matrices de calor sirven para representar el riesgo, no para calibrarlo; la probabilidad debe referirse a un lapso definido, y la confidencialidad, la integridad y la disponibilidad deben modelarse por separado [14]. Cuando no se dispone de datos históricos suficientes, la guía

admite la opinión de expertos calibrada, por ejemplo mediante el método Delphi, y su validación con métricas como el *Brier score* [14]. Ninguno de los trabajos aplicados al sector educativo revisados incorpora estas exigencias.

1.2.3 Gestión de riesgos de seguridad de la información en el sector público y educativo

Patiño et al. [29] constituyen el antecedente ecuatoriano más directo de adaptación de ISO/IEC 27005 a un contexto institucional, mediante una guía por pasos para entidades del sector público. López-Vasco et al. [21] trasladan ese tipo de enfoque a la educación superior tecnológica, con un diagnóstico y un plan de controles basados en ISO/IEC 27001. En el plano internacional, la revisión de Ulven y Wangen [2] sintetiza los activos críticos, las amenazas y las vulnerabilidades más frecuentes en universidades y concluye en nueve riesgos estratégicos, mientras que Li et al. [3] identifican factores organizacionales que explican la ocurrencia de brechas de datos en universidades, como la divulgación de vulnerabilidades y el uso de servicios en la nube. Estos trabajos proporcionan catálogos de amenazas y evidencia útil para estimar la probabilidad, pero valoran el riesgo desde la perspectiva de los activos de la organización y no desde el daño a los titulares, que es el eje de la LOPDP y de la guía de la SPDP.

1.2.4 Protección de datos personales en instituciones de educación superior

Un conjunto de estudios aborda la protección de datos en las IES desde el cumplimiento normativo. Habbabeh et al. [31] constataron que la literatura ofrecía escasa orientación para que las universidades verificaran su cumplimiento del RGPD y, siguiendo los lineamientos de la ciencia del diseño, construyeron un instrumento de 44 controles cuya puntuación total indica el grado de alineación de la institución con el reglamento y que puede emplearse como herramienta de gestión para el seguimiento de medidas. Fernandes et al. [5] identificaron dieciséis factores críticos de éxito para implementar el RGPD en universidades públicas portuguesas, entre ellos el compromiso de la alta dirección y la cultura de protección de datos. Vanezi et al. [32] documentaron la incorporación de requisitos del RGPD desde el diseño en una plataforma de aprendizaje en línea.

Otro grupo de trabajos se concentra en los tratamientos derivados de la analítica del aprendizaje. Gursoy et al. [30] examinaron técnicas de anonimización y de privacidad diferencial aplicadas a datos educativos; Tsai et al. [33] analizaron la brecha entre las expectativas de privacidad de los estudiantes y su conducta efectiva, con énfasis en la transparencia y la confianza; y Liu y Khalil [4] identificaron ocho

problemas interrelacionados de privacidad a lo largo del ciclo de vida de esos datos. Desde la perspectiva de los titulares, Maguraushe et al. [34] aplicaron una encuesta diagnóstica sobre conciencia, expectativas y confianza de los estudiantes en materia de privacidad en el sector de educación superior de un país en desarrollo, instrumento que puede adaptarse a la fase de diagnóstico. En conjunto, estos estudios aportan controles, factores de éxito e instrumentos de medición, pero miden el cumplimiento o la percepción y no el riesgo, por lo que no distinguen entre riesgo inherente y residual ni priorizan el tratamiento.

1.2.5 Antecedentes latinoamericanos y ecuatorianos

En América Latina, Guerrero Argote [35] mapeó 267 universidades de Argentina, Chile y Perú y encontró que 46 utilizaban *software* de supervisión remota de exámenes (*e-proctoring*), con mayor adopción en las universidades privadas; ocho de los nueve productos identificados incorporaban reconocimiento facial y trataban imágenes, voz, rasgos faciales y datos de navegación, y el autor reportó un bajo cumplimiento de las obligaciones de registro de bases de datos. Zappelini et al. [8] mostraron que, en Brasil, el uso de medios digitales para la docencia y la evaluación remota plantea riesgos específicos cuando los titulares son adolescentes. En Colombia, la Superintendencia de Industria y Comercio presentó en 2026 una guía sobre el tratamiento de datos personales en el contexto universitario, que recuerda que las IES son responsables del tratamiento de los datos de su comunidad, exige separar las finalidades necesarias para el servicio educativo de las opcionales y recomienda designar un oficial de protección de datos y reforzar la seguridad de la información sensible [40]. Estos antecedentes confirman que los riesgos identificados en Europa se reproducen en la región, con el agravante de marcos de control aún en consolidación.

En Ecuador, Álvarez-Carrión y Hernández-Sotomayor [19] concluyeron que la LOPDP ofrece un marco sólido, pero que su implementación en plataformas educativas enfrenta brechas de infraestructura y de capacitación, con fallos técnicos y error humano como causas principales de las vulneraciones documentadas; Piray Rodríguez et al. [20] observaron una adopción desigual de políticas internas de protección de datos entre universidades. La normativa técnica de la SPDP —la guía de gestión de riesgos en sus dos versiones y la norma de gran escala— es posterior a la mayoría de estos estudios [12, 14, 15], por lo que ningún antecedente nacional la ha incorporado todavía.

1.2.6 Análisis comparativo y brecha identificada

La Tabla 3 contrasta los marcos y trabajos más cercanos con seis criterios que se derivan de la LOPDP y de la guía de la SPDP: la valoración del riesgo desde la perspectiva de los titulares; la cobertura del ciclo completo de gestión (contexto, identificación, análisis, evaluación y tratamiento); la integración de la EIPD; la exigencia de estimaciones justificadas; la aplicación al sector de la educación superior, y la alineación con la normativa ecuatoriana.

Tabla 3: Comparación de marcos y trabajos relacionados con los requisitos del proyecto.

Marco o trabajo	Enfoque titulares	Ciclo completo	EIPD	Estimación justificada	Sector IES	Normativa Ecuador
ISO/IEC 27005:2022 [41]	No	Sí	No	Parcial	No	No
ISO/IEC 29134:2023 [36]	Sí	Parcial	Sí	No	No	No
AEPD (2021) [37]	Sí	Sí	Sí	Parcial	No	No
NIST Privacy Framework [38]	Sí	Parcial	No	No	No	No
LINDDUN [22]	Sí	Parcial	No	No	No	No
FAIR bayesiano [28]	No	Parcial	No	Sí	No	No
Guía SPDP V.2 [14]	Sí	Sí	Sí	Sí	No	Sí
Patiño et al. [29]	No	Sí	No	No	No	Sí
López-Vasco et al. [21]	No	Parcial	No	No	Sí	Sí
Habbabeh et al. [31]	Parcial	No	No	No	Sí	No
Metodología propuesta	**Sí**	**Sí**	**Sí**	**Sí**	**Sí**	**Sí**

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia a partir de las fuentes citadas

La comparación muestra que ningún marco ni trabajo revisado satisface a la vez los seis criterios. Los marcos internacionales de privacidad adoptan la perspectiva de los titulares, pero no responden a la normativa ecuatoriana ni a las particularidades de una IES; los modelos de seguridad de la información aplicados en el país cubren el ciclo de gestión, pero sobre activos de la organización; los estudios sectoriales miden el cumplimiento o la percepción, no el riesgo; y la guía de la SPDP, aunque fija el marco obligatorio, es deliberadamente general y no ofrece una aplicación al sector educativo. El vacío que se identifica, por tanto, es la ausencia de una metodología que integre la evaluación de riesgos sobre los derechos de los titulares, las obligaciones de la LOPDP y de su reglamento, y las etapas y reglas de estimación definidas por la SPDP en el contexto específico de una IES ecuatoriana. Este trabajo se orienta a cubrir ese vacío.

1.3 Planteamiento del Problema

Las IES tratan grandes volúmenes de datos personales académicos, administrativos y de salud sin contar necesariamente con procesos sistemáticos de diagnóstico y gestión de riesgos alineados a la LOPDP, lo que genera exposición legal y vulnerabilidad de la información. La normativa exige una metodología de análisis de riesgos y, en los casos de tratamiento a gran escala de categorías especiales, una evaluación de impacto previa [10, 15]; no obstante, la evidencia nacional muestra una adopción desigual de políticas y brechas de capacidad técnica y humana en las universidades [19, 20].

1.3.1 Análisis crítico

El análisis del problema se estructuró mediante un árbol de problemas que relaciona sus causas con el problema central y con los efectos que produce. La Tabla 4 presenta esa relación y la Figura 1 la representa de forma gráfica.

Tabla 4: Árbol de problemas: causas, problema central y efectos.

Causas	**Problema central**	**Efectos**
C1. Ausencia de un inventario o registro de actividades de tratamiento que identifique procesos, datos y titulares.	**Las IES tratan grandes volúmenes de datos personales sin procesos sistemáticos de diagnóstico y gestión de riesgos alineados a la LOPDP, lo que genera exposición legal y vulnerabilidad de la información.**	E1. Exposición a sanciones por infracciones graves (arts. 68 y 72 de la LOPDP).
C2. Enfoque de seguridad centrado en activos tecnológicos y no en los derechos de los titulares.		E2. Vulnerabilidad de la información ante incidentes de confidencialidad, integridad y disponibilidad.
C3. Desconocimiento de la normativa técnica reciente de la SPDP (guía de riesgos, gran escala).		E3. Evaluaciones de impacto omitidas o realizadas sin las etapas previas exigidas.
C4. Brechas de capacitación y cultura de protección de datos en el personal.		E4. Incapacidad de notificar vulneraciones dentro del término legal de cinco días.
C5. Uso creciente de plataformas en la nube y servicios de terceros sin evaluación de riesgos.		E5. Pérdida de confianza de estudiantes y docentes y daño reputacional.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [10, 15, 19, 2]

La primera causa es la falta de un inventario de tratamientos. Sin conocer qué procesos tratan datos, qué categorías intervienen y cuántos titulares se ven afectados,

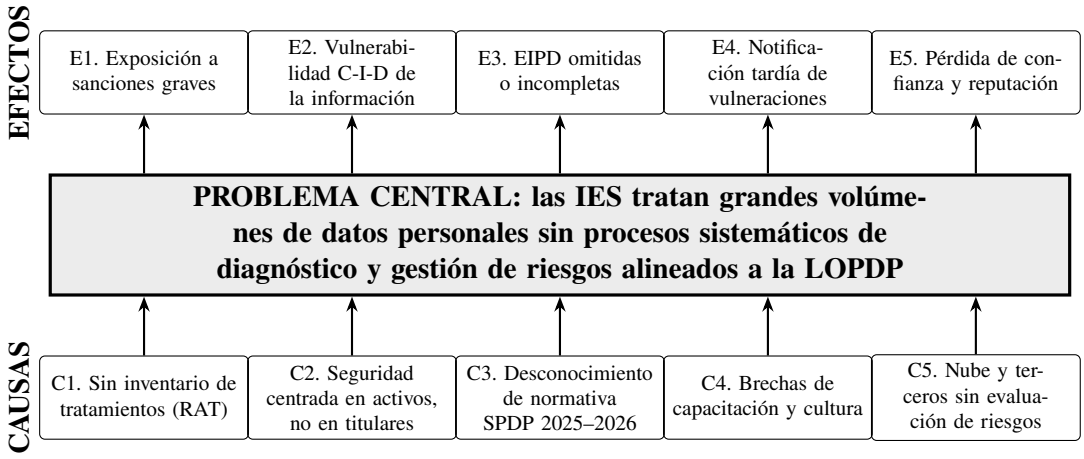


Figura 1: Árbol de problemas.
Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

no es posible aplicar los criterios del artículo 40 de la LOPDP ni calcular si un tratamiento alcanza el umbral de gran escala definido por la SPDP [15]. La segunda causa es de enfoque: los modelos aplicados en el sector, como los descritos por Patiño et al. [29] y López-Vasco et al. [21], valoran el riesgo sobre los activos de la organización, mientras que la LOPDP pone en el centro los derechos y libertades de los titulares. La tercera causa obedece a la velocidad del cambio normativo, pues entre 2025 y 2026 la SPDP expidió la guía de riesgos, su segunda versión y la norma de gran escala, lo que supone una carga de actualización para las IES. La cuarta causa, vinculada al factor humano, coincide con el hallazgo de Álvarez-Carrión y Hernández-Sotomayor [19] sobre el peso del error humano en los incidentes de universidades ecuatorianas y con la relevancia que Fernandes et al. [5] asignan a la capacitación y a la cultura de protección de datos. La quinta causa responde a la migración de servicios académicos hacia plataformas de terceros, en las que la IES sigue siendo responsable del tratamiento.

Entre los efectos destaca la exposición legal, que en este caso es directa: carecer de una metodología de análisis y gestión de riesgos ya configura la infracción grave del artículo 68, numeral 4. Para una IES particular, las infracciones graves se sancionan con multas de entre el 0,7 % y el 1 % de su volumen de negocio del ejercicio anterior [10, art. 72], y las primeras sanciones impuestas por la SPDP demuestran que la autoridad ya aplica ese régimen [16]. A ello se suman la vulnerabilidad técnica, con la consecuente afectación a titulares, y la incapacidad de responder a tiempo ante una vulneración, dado que el plazo de notificación es breve y presupone que la institución ha identificado de antemano sus escenarios de riesgo.

1.3.2 Prognosis

De no abordarse el problema, las IES continuarían tratando datos de estudiantes y docentes sin conocer con certeza cuáles de sus tratamientos son de alto riesgo ni cuáles exigen una evaluación de impacto previa, con lo que quedarían en situación de incumplimiento frente a los artículos 40 y 42 de la LOPDP y a la Resolución SPDP-SPD-2026-0005-R. En un escenario de incidente, la ausencia de escenarios de riesgo y de un procedimiento de respuesta dificultaría cumplir el término de notificación de cinco días del artículo 43, lo que agravaría la responsabilidad de la institución. La tendencia regional de ataques contra universidades [7, 6, 1] permite prever que la probabilidad de un incidente no disminuirá por sí sola, y la actividad sancionadora de la SPDP [16] indica que las consecuencias jurídicas de no gestionar el riesgo serán cada vez más tangibles. En el plano institucional, cada unidad seguiría aplicando criterios propios y no comparables, lo que impediría priorizar inversiones en controles y demostrar responsabilidad proactiva ante la autoridad.

1.3.3 Formulación del problema

¿Cómo diagnosticar y gestionar de forma sistemática los riesgos del tratamiento de datos personales de estudiantes y docentes en una institución de educación superior, de modo que se cumplan las exigencias de la LOPDP y de la normativa técnica de la SPDP?

1.3.4 Preguntas directrices

La investigación se orienta mediante cinco preguntas directrices, cada una vinculada a un objetivo específico (OE). ¿Cuáles son los procesos actuales de tratamiento de datos personales en la institución o unidad seleccionada y en qué condiciones se ejecutan? (OE1). ¿Qué fases, actividades y criterios debe contener una metodología de identificación, evaluación, mitigación y monitoreo de riesgos alineada a la LOPDP y a la guía de la SPDP? (OE2). ¿Qué resultados se obtienen al aplicar la metodología en un caso de estudio real o simulado dentro de la institución? (OE3). ¿Qué riesgos inherentes y residuales se identifican y cómo se priorizan en una matriz derivada de esa aplicación? (OE4). ¿Qué recomendaciones de mejora continua permiten a la institución mantener la gestión de riesgos alineada a la LOPDP? (OE5).

1.3.5 Delimitación

En cuanto al contenido, el estudio pertenece al campo de las tecnologías de la información, en el área de gobernanza y seguridad de la información, y se centra

en la gestión de riesgos sobre el tratamiento de datos personales de estudiantes y docentes conforme a la LOPDP, su reglamento y la normativa técnica de la SPDP. En lo espacial, se desarrolla en la Universidad Tecnológica Indoamérica, sede Quito, en la unidad o proceso que se acuerde con la tutoría. En lo temporal, se ejecuta durante el periodo académico B26, con una duración prevista de seis meses de dedicación completa, y considera la normativa vigente hasta la fecha de cierre del trabajo.

1.4 Justificación

La importancia del trabajo radica en que la gestión de riesgos ha dejado de ser una buena práctica opcional para convertirse en una obligación jurídica. La LOPDP exige al responsable una metodología de análisis de riesgos y un proceso de evaluación continua de sus medidas de seguridad [10, arts. 37 y 40], y la SPDP ha concretado esa exigencia mediante una guía con un capítulo de cumplimiento obligatorio [12] y una norma que califica directamente como de gran escala los tratamientos de datos de salud y de adolescentes en entornos educativos [15]. Las IES, que tratan estos datos de forma habitual, requieren una herramienta que traduzca esas obligaciones a su realidad operativa.

La novedad del aporte reside en la integración de elementos que la literatura aborda por separado. Los antecedentes revisados ofrecen metodologías generales de evaluación de impacto [26, 25] o modelos de seguridad de la información centrados en activos [21, 29], pero no una metodología específica para IES ecuatorianas que adopte la perspectiva de los titulares exigida por la LOPDP y siga las etapas de la guía de la SPDP. Este vacío coincide con la escasez de investigación empírica sobre riesgos en la educación superior señalada por Ulven y Wangen [2].

La utilidad del proyecto se expresa en sus productos: un documento metodológico por fases y una matriz de riesgos aplicada, concebida como plantilla reutilizable en hoja de cálculo, que la institución podrá emplear para priorizar controles, documentar su responsabilidad proactiva y preparar evaluaciones de impacto. La factibilidad es técnica, operativa y económica, porque el trabajo se apoya en normas de acceso público, en herramientas ofimáticas de uso común y en el acceso a información institucional bajo las debidas autorizaciones, sin requerir infraestructura adicional.

Los beneficiarios directos son la institución, en su calidad de responsable del tratamiento, y las unidades académicas y administrativas que intervienen en el caso de estudio; los beneficiarios indirectos son los estudiantes y docentes, cuyos derechos se protegen mejor cuando los riesgos se identifican y tratan de forma anticipada, así como otras IES que podrán replicar la metodología. El impacto esperado es la

reducción de la exposición legal y de la vulnerabilidad de la información, junto con una mejora de la confianza de la comunidad universitaria.

El trabajo se inscribe en la línea de investigación Gestión de la Información, sublínea Gobernanza y seguridad de la información, y en el eje de aplicación Tecnologías para la educación. Asimismo, contribuye a las competencias del perfil de egreso PE-CP-06, que consiste en evaluar proyectos de TI en el ámbito de las buenas prácticas y en concordancia con el marco legal vigente; PE-MI-04, relativa a gestionar proyectos de TI aplicando conceptos éticos, legales, económicos y financieros para la toma de decisiones; PE-IS-04, referida a realizar proyectos de investigación sobre problemas técnicos de la profesión siguiendo una metodología científica; y PE-PP-05, que corresponde a implementar sistemas de seguridad informática bajo políticas organizacionales y estándares aceptados, con ética y responsabilidad.

1.5 Objetivos

1.5.1 Objetivo General

Diseñar una metodología de diagnóstico y gestión de riesgos para el tratamiento de datos personales de estudiantes y docentes en instituciones de educación superior, mediante la integración de las etapas de la guía de gestión de riesgos y evaluación de impacto de la SPDP con la norma ISO/IEC 27005:2022, para contribuir al cumplimiento de las obligaciones de análisis de riesgos y evaluación de impacto establecidas en la Ley Orgánica de Protección de Datos Personales (2021) y en su Reglamento General (2023).

1.5.2 Objetivos Específicos

1. Diagnosticar los procesos actuales de tratamiento de datos personales en la unidad seleccionada de la institución, mediante revisión documental, entrevistas a actores clave y un cuestionario de madurez, para establecer la línea base de cumplimiento respecto de la LOPDP (2021) y su Reglamento General (2023).

2. Diseñar las fases de la metodología —identificación, evaluación, mitigación y monitoreo de riesgos—, mediante la adaptación de las etapas de la guía de la SPDP y de la norma ISO/IEC 27005:2022, para orientar a la institución en un proceso sistemático, documentado y centrado en los derechos de los titulares.

3. Aplicar la metodología en un caso de estudio real o simulado dentro de la

institución, mediante la identificación y el análisis de escenarios de riesgo con criterio de expertos, para comprobar su aplicabilidad en el tratamiento de datos de estudiantes y docentes.

4. Elaborar una matriz de riesgos inherentes y residuales derivada del caso de estudio, mediante criterios de probabilidad e impacto justificados en una plantilla reutilizable de hoja de cálculo, para priorizar el tratamiento de los riesgos y sustentar la evaluación de impacto prevista en el artículo 42 de la LOPDP.

5. Formular recomendaciones de mejora continua, mediante la validación de los resultados con actores institucionales, para mantener la gestión de riesgos alineada a la LOPDP (2021), a su Reglamento General (2023) y a la normativa técnica de la SPDP.

1.6 Alcance del Proyecto

El alcance del proyecto comprende la revisión de los procesos actuales de tratamiento de datos personales en la institución o unidad seleccionada; el diseño de una metodología con fases de identificación, evaluación, mitigación y monitoreo de riesgos, precedidas por una fase de diagnóstico de madurez y articuladas con las etapas de la guía de la SPDP; la aplicación de la metodología en un caso de estudio real o simulado dentro de la institución; la generación de una matriz de riesgos inherentes y residuales en una plantilla reutilizable; y la formulación de recomendaciones de mejora continua alineadas a la LOPDP. La metodología se validará con actores institucionales mediante criterio de expertos.

El proyecto excluye de manera expresa tres aspectos. En primer lugar, no incluye la certificación legal formal ante la autoridad de protección de datos, por lo que sus resultados no constituyen una declaración de cumplimiento ante la SPDP. En segundo lugar, no cubre la implementación completa de todas las medidas correctivas recomendadas, que corresponderá a la institución según sus prioridades y recursos. En tercer lugar, no abarca una auditoría externa independiente; las revisiones que se realicen tendrán carácter interno y académico.

Entre las limitaciones se reconoce, primero, que el acceso a información institucional depende de las autorizaciones que se obtengan, razón por la cual el caso de estudio podrá ser simulado y toda evidencia se tratará de forma anonimizada o agregada. Segundo, la estimación de probabilidades e impactos se apoyará en criterio de expertos, con la incertidumbre propia de ese tipo de juicio, aunque cada valor

se acompañará de su justificación conforme exige la guía de la SPDP. Tercero, la normativa técnica de la SPDP se encuentra en evolución, por lo que la metodología se ajustará a la vigente a la fecha de cierre del trabajo.

1.7 Fundamentación Teórica

Un dato personal es aquel que identifica o hace identificable a una persona natural, y el tratamiento comprende cualquier operación realizada sobre esos datos, desde su recolección hasta su eliminación [10, art. 4]. La LOPDP distingue al responsable, que decide sobre la finalidad y el tratamiento, del encargado, que trata datos por cuenta de aquel, y reconoce categorías especiales que requieren protección reforzada: datos sensibles, datos de niñas, niños y adolescentes, datos de salud y datos de personas con discapacidad (art. 25). En una IES, la institución actúa como responsable y los proveedores de plataformas académicas suelen actuar como encargados.

La gestión de riesgos se entiende como el conjunto de actividades coordinadas para dirigir y controlar una organización con respecto al riesgo [42]. La norma ISO/IEC 27005:2022 desarrolla ese marco para la seguridad de la información mediante un proceso que comprende el establecimiento del contexto, la identificación, el análisis, la evaluación y el tratamiento de riesgos, junto con su comunicación y seguimiento [41]; la guía de la SPDP adopta esas mismas etapas y las orienta hacia la protección de los derechos de los titulares [12]. La norma ISO/IEC 27701:2025 complementa el enfoque con requisitos para un sistema de gestión de la información de privacidad [43].

La evaluación de impacto relativa a la protección de datos (EIPD) es el análisis previo de un tratamiento que probablemente conlleve un alto riesgo para los derechos y libertades de los titulares [10, art. 42]. La literatura la distingue del análisis de riesgos de seguridad porque su objeto es el daño a las personas y no la pérdida para la organización [25]. En cuanto a la estimación del riesgo, coexisten enfoques cualitativos, basados en escalas y criterio de expertos, y enfoques cuantitativos como el modelo FAIR, que estima la frecuencia y la magnitud de las pérdidas mediante simulación y redes bayesianas [28]. Distinguir entre riesgo inherente, previo a los controles, y riesgo residual, posterior a ellos, permite medir el efecto de las medidas propuestas, que es precisamente lo que el artículo 37 de la LOPDP exige evidenciar. Estos conceptos se desarrollarán con mayor profundidad en el marco de la metodología propuesta.

CAPÍTULO II

METODOLOGÍA

El presente capítulo describe la situación de partida del caso de estudio, el área en la que se inscribe el trabajo, el enfoque metodológico que guía la investigación, las técnicas e instrumentos de recolección de información, los requisitos que debe cumplir la metodología propuesta y su diseño. Conforme a lo acordado con la tutoría, el caso de estudio es **simulado** y se centra en el **proceso de admisión y matrícula** de una institución de educación superior particular ecuatoriana. La simulación permite aplicar la metodología con un nivel de detalle realista sin tratar datos personales reales ni comprometer información institucional, de acuerdo con las limitaciones y exclusiones declaradas en el Capítulo I.

2.1 Diagnóstico de la Situación Actual

2.1.1 Caracterización del caso simulado

El caso se construyó sobre una institución ficticia, denominada en adelante *IES simulada* (IES-S), cuyas características reproducen las de una universidad particular de tamaño medio con sede en Quito. Los parámetros de la Tabla 5 son ficticios, se definieron únicamente para dimensionar el caso y no corresponden a la Universidad Tecnológica Indoamérica ni a otra institución identificable. Su función es permitir que la metodología se ejercite sobre volúmenes, categorías de datos y relaciones con terceros verosímiles, en particular para valorar el número de titulares afectados y la presencia de categorías especiales, que son criterios de impacto exigidos por la guía de la SPDP [14].

2.1.2 Descripción del proceso de admisión y matrícula

El proceso de admisión y matrícula se eligió porque concentra, en un periodo breve, la recolección masiva de datos de personas que aún no tienen vínculo con la institución, incluye categorías especiales de datos —discapacidad, condición socio-económica y datos de adolescentes— e involucra a varias unidades y proveedores externos. Esta combinación lo vuelve representativo de los riesgos que la LOPDP

Tabla 5: Parámetros del caso simulado (IES-S).

Parámetro	**Valor ficticio**
Tipo de institución	Universidad particular, modalidad presencial y en línea
Estudiantes matriculados	Aproximadamente 6 000
Aspirantes por periodo académico	Aproximadamente 2 500, de los cuales cerca del 10 % son menores de edad al momento de la postulación
Periodos de admisión por año	Dos
Estudiantes con beca o arancel diferenciado	Aproximadamente 1 200
Estudiantes que declaran discapacidad	Aproximadamente 150
Unidades que intervienen en el proceso	Admisiones, Secretaría Académica, Bienestar Estudiantil, Dirección Financiera, Dirección de Tecnologías de la Información
Sistemas de información	Portal web de postulación, sistema de gestión académica (SGA), sistema financiero y de facturación, suite de correo y almacenamiento en la nube, plataforma de aprendizaje (LMS)
Proveedores externos (encargados)	Pasarela de pagos, proveedor de la suite en la nube, proveedor de la LMS en modalidad SaaS, proveedor de CRM de admisiones
Delegado de protección de datos	No designado formalmente

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia (datos ficticios)

pretende controlar [10, arts. 25 y 40] y lo sitúa dentro de los supuestos de tratamiento a gran escala definidos por la SPDP, que incluyen el tratamiento sistemático de datos de niñas, niños y adolescentes en entornos educativos [15]. La Tabla 6 desagrega el proceso en seis subprocesos.

Tabla 6: Subprocesos del proceso de admisión y matrícula en la IES-S.

Subproceso	**Datos personales tratados**	**Titulares**	**Sistemas y terceros**
SP1. Registro y postulación	Identificación (cédula o pasaporte), contacto, fecha de nacimiento, colegio de procedencia, fotografía	Aspirantes; representantes de menores	Portal web; CRM de admisiones (encargado)
SP2. Admisión y nivelación	Calificaciones de bachillerato, resultados de la prueba de admisión, entrevista	Aspirantes	SGA; correo institucional
SP3. Becas y aranceles diferenciados	Ficha socioeconómica, ingresos del hogar, certificado de discapacidad, datos de salud en casos de excepción	Aspirantes y su núcleo familiar	Formularios en la nube; Bienestar Estudiantil
SP4. Pago de matrícula	Datos de facturación, datos de la tarjeta o cuenta bancaria del pagador	Estudiantes; pagadores (padres, terceros)	Sistema financiero; pasarela de pagos (encargado)
SP5. Legalización de la matrícula	Expediente completo, creación de cuentas institucionales, asignación de paralelos	Estudiantes	SGA; suite en la nube y LMS (encargados)
SP6. Reportes y archivo	Datos agregados y nominales para reportes a organismos de control; expedientes de aspirantes no admitidos	Estudiantes y aspirantes	SGA; repositorios de archivo

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia (caso simulado)

2.1.3 Limitaciones de la situación actual

El escenario simulado incorpora de forma deliberada debilidades que la literatura reporta como frecuentes en el sector, con el fin de que la metodología se ponga a prueba frente a condiciones realistas. Las revisiones de Ulven y Wangen [2] y de Álvarez-Carrión y Hernández-Sotomayor [19] señalan como causas recurrentes de incidentes en universidades el error humano, los fallos técnicos y la gestión deficiente de accesos, mientras que Li et al. [3] vinculan la ocurrencia de brechas con decisiones

organizacionales sobre vulnerabilidades y plataformas. Sobre esa base, la situación inicial de la IES-S presenta las siguientes limitaciones, que la fase de diagnóstico (OE1) deberá confirmar o descartar con evidencia:

1. No existe un registro de actividades de tratamiento (RAT) que identifique, por subproceso, las finalidades, las categorías de datos, los titulares, los destinatarios y los plazos de conservación.

2. El formulario de postulación emplea una cláusula de consentimiento genérica que no distingue las finalidades necesarias para la admisión de las finalidades comerciales o de difusión.

3. Los certificados de discapacidad y las fichas socioeconómicas se reciben por correo electrónico y se almacenan en carpetas compartidas en la nube, sin una clasificación de la información que restrinja su acceso.

4. Los perfiles de acceso al SGA se asignan por unidad y no por función, lo que otorga privilegios excesivos al personal administrativo de temporada.

5. Los expedientes de los aspirantes no admitidos se conservan indefinidamente.

6. Los contratos con la pasarela de pagos y con el proveedor de CRM no contienen cláusulas específicas de protección de datos.

7. No existe un procedimiento documentado de gestión y notificación de vulneraciones de seguridad que permita cumplir el término de cinco días del artículo 43 de la LOPDP [10, art. 43].

8. La gestión de la seguridad se enfoca en la disponibilidad de los sistemas y no evalúa el impacto que un incidente tendría sobre los titulares.

Estas condiciones configuran el problema central planteado en el Capítulo I: el tratamiento de un volumen elevado de datos, que incluye categorías especiales, sin un proceso sistemático de diagnóstico y gestión de riesgos alineado a la LOPDP.

2.2 Área de Estudio

La Tabla 7 sintetiza el dominio, el área y el objeto de estudio del proyecto.

Tabla 7: Área de estudio.

Dominio:	Gobernanza de la información y protección de datos personales
Línea de investigación:	Gestión de la información
Sublínea de investigación:	Gobernanza y seguridad de la información.
Campo:	Tecnologías de la información y la comunicación (TIC)
Área:	Gestión de riesgos sobre el tratamiento de datos personales y evaluación de impacto
Aspectos:	Inventario de tratamientos, identificación de amenazas y vulnerabilidades, estimación de probabilidad e impacto sobre los titulares, tratamiento del riesgo, monitoreo y cumplimiento de la LOPDP, su reglamento y la normativa técnica de la SPDP
Objeto de estudio:	Proceso de admisión y matrícula de una institución de educación superior particular simulada (IES-S), con base en el contexto de las IES ecuatorianas
Periodo de estudio:	Periodo académico B26, con una duración de seis meses a partir de la aprobación de la propuesta (2026–2027)

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

2.3 Metodología de Desarrollo o Implementación

2.3.1 Enfoque y tipo de investigación

La investigación es de tipo aplicado, porque busca resolver un problema concreto de cumplimiento normativo en las IES, y de alcance descriptivo-propositivo, porque describe la situación de un proceso de tratamiento y propone un artefacto metodológico para gestionarlo. Se adopta un enfoque mixto: el diagnóstico y la validación combinan información cualitativa, obtenida mediante revisión documental, entrevistas y juicio de expertos, con información cuantitativa, como los niveles de madurez, las estimaciones de probabilidad y las métricas de calibración. El diseño es no experimental, dado que no se manipulan variables, sino que se observa y modela un proceso en su contexto [44].

2.3.2 Ciencia del diseño como marco metodológico

Dado que el producto principal del trabajo es un artefacto —una metodología acompañada de una matriz de riesgos reutilizable—, el desarrollo se rige por la investigación en ciencia del diseño (*Design Science Research*, DSR). Hevner et al. [45] establecen que la ciencia del diseño en sistemas de información produce artefactos, como constructos, modelos, métodos e instanciaciones, que deben ser rigurosamente evaluados en función de su utilidad para resolver un problema relevante. Peffers et al. [46] operacionalizaron este paradigma en un proceso de seis actividades: identificación del problema y motivación, definición de los objetivos de la solución, diseño y desarrollo, demostración, evaluación y comunicación. La Tabla 8 relaciona esas actividades con las fases de la investigación definidas en la propuesta, los objetivos específicos y los entregables.

2.3.3 Unidad de análisis, población y muestra

La unidad de análisis es el proceso de admisión y matrícula de la IES-S, desagregado en los seis subprocesos de la Tabla 6. Al tratarse de un caso simulado, no se recolectan datos de estudiantes ni de aspirantes; los titulares se representan mediante registros ficticios y perfiles agregados.

La población de informantes está constituida por profesionales con experiencia en protección de datos personales, seguridad de la información, gestión académica o derecho informático. La muestra es no probabilística e intencional [44], compuesta por un panel de al menos cinco expertos, número mínimo que la guía de la SPDP establece para la estimación mediante el método Delphi [14]. Los criterios de se-

Tabla 8: Relación entre las actividades DSR, las fases de la investigación y los objetivos específicos.

Actividad DSR	Fase de la investigación	OE	Entregable
1. Identificación del problema y motivación	Diagnóstico situacional	OE1	Caracterización del proceso, RAT preliminar e informe de madurez
2. Definición de los objetivos de la solución	Diagnóstico situacional	OE1, OE2	Requisitos de la metodología (Sección 2.5)
3. Diseño y desarrollo	Diseño metodológico	OE2	Metodología por fases, criterios de estimación y plantilla de matriz (Sección 2.6)
4. Demostración	Aplicación en el caso de estudio	OE3, OE4	Expediente del caso simulado y matriz de riesgos inherentes y residuales
5. Evaluación	Validación con actores institucionales	OE5	Resultados del panel de expertos y de la calibración; recomendaciones de mejora continua
6. Comunicación	Documentación final	OE5	Trabajo de integración curricular y anexos

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [46]

lección son: (a) título de tercer nivel en tecnologías de la información, sistemas, derecho o afines; (b) al menos tres años de experiencia en seguridad de la información, protección de datos o gestión de procesos académicos en IES, y (c) ausencia de conflicto de interés con el caso. Los expertos se identifican mediante códigos (E01, E02, . . .) y participan con consentimiento informado.

2.4 Técnicas e Instrumentos de Recolección de Información

La Tabla 9 resume las técnicas e instrumentos previstos, los informantes o fuentes y el objetivo al que tributa cada uno. Los instrumentos se presentan en los Anexos A a G, y la plantilla de la matriz de riesgos, en el Anexo H.

2.4.1 Método Delphi y calibración de las estimaciones

El método Delphi es una técnica estructurada de consulta a expertos que se desarrolla en rondas sucesivas, de forma anónima y con retroalimentación controlada, hasta alcanzar un nivel aceptable de consenso [47]. En este trabajo se emplea para estimar la probabilidad anual y el impacto de cada escenario de riesgo cuando no existen datos históricos suficientes, que es la situación habitual en un caso simulado y en las IES que inician su gestión de riesgos. Cada experto registra su estimación y

Tabla 9: Técnicas e instrumentos de recolección de información.

Técnica	**Instrumento**	**Fuente o informante**	**OE**
Revisión documental	Lista de verificación de requisitos de la LOPDP, su reglamento y la normativa de la SPDP aplicables al proceso	Normativa vigente; documentos simulados de la IES-S (políticas, formularios, contratos)	OE1
Entrevista semiestructurada	Guía de entrevista por subproceso (finalidades, datos, accesos, conservación, terceros, incidentes)	Responsables simulados de cada unidad; expertos del panel	OE1
Encuesta	Cuestionario de madurez en protección de datos, con escala de cinco niveles por dominio	Responsables simulados; validación de contenido por expertos	OE1
Auditoría de procesos	Lista de verificación jurídica, organizacional y técnica orientada a la práctica efectiva y no solo a la política escrita	Expediente del caso simulado	OE1, OE3
Método Delphi	Cuestionarios iterativos de estimación de probabilidad e impacto con justificación (*rationale*)	Panel de al menos cinco expertos	OE3, OE4
Juicio de expertos	Instrumento de validación de la metodología (pertinencia, claridad, coherencia normativa y aplicabilidad), escala de Likert de cinco puntos	Panel de expertos	OE5

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

su justificación; tras cada ronda se le devuelve la mediana y el rango intercuartílico del panel, junto con los argumentos anonimizados, y se le permite revisar su respuesta. Se prevén como máximo tres rondas y se considera alcanzado el consenso cuando el rango intercuartílico no supera un nivel de la escala.

Para cumplir la exigencia de la guía de la SPDP de validar las estimaciones [14], los expertos responden además una batería de preguntas de calibración con respuesta conocida, expresando su grado de confianza como una probabilidad. La calidad de esas respuestas se mide con el puntaje de Brier [48], definido en la Ecuación 1:

$$BS = \frac{1}{N} \sum_{t=1}^{N} (f_t - o_t)^2 \tag{1}$$

donde N es el número de preguntas, f_t es la probabilidad asignada por el experto a la pregunta t y o_t toma el valor 1 si el evento ocurrió (o la afirmación es verdadera) y 0 en caso contrario. El puntaje varía entre 0, que corresponde a una calibración perfecta, y 1; un experto que respondiera siempre con una probabilidad de 0,5 obtendría 0,25, valor que se adopta como umbral de referencia. Las estimaciones de los expertos con mejor calibración se emplean para ponderar las respuestas del panel.

2.4.2 Consideraciones éticas

El trabajo se rige por las siguientes reglas: (a) no se tratan datos personales reales; todos los registros del caso son ficticios o seudonimizados; (b) los expertos se identifican con códigos y firman un consentimiento informado que describe la finalidad, el uso de la información y su derecho a retirarse; (c) los hallazgos se redactan en términos de procesos y controles, nunca de personas, y (d) el autor declara que desempeña funciones de administración de sistemas en la infraestructura de la institución en la que estudia; para evitar conflictos de interés, ningún sistema que administre se utiliza como fuente de información del caso y toda referencia a la UTI se limita a información pública.

2.5 Requerimientos del Proyecto

Dado que el artefacto es una metodología y no un sistema informático, los requerimientos se expresan como requisitos que la metodología debe satisfacer. Los requisitos funcionales describen lo que la metodología debe permitir hacer y se derivan de la LOPDP y de la guía de la SPDP; los no funcionales describen las

cualidades que debe tener para ser adoptada por una IES.

2.5.1 Requerimientos Funcionales

La Tabla 10 enumera los requisitos funcionales y su fundamento normativo.

Tabla 10: Requisitos funcionales de la metodología.

ID	Requisito	Fundamento
RF01	Diagnosticar el nivel de madurez de la institución en protección de datos antes de iniciar la gestión de riesgos.	LOPDP art. 37; fase 0 propuesta
RF02	Inventariar las actividades de tratamiento (RAT) con finalidades, categorías de datos, titulares, destinatarios, encargados y plazos de conservación.	LOPDP art. 40; guía SPDP (contexto)
RF03	Identificar vulnerabilidades de cuatro tipos: jurídicas, organizacionales, técnicas y relativas a grupos vulnerables de titulares.	Guía SPDP
RF04	Construir escenarios de riesgo con comunidad de amenaza, vector, vulnerabilidades e impacto primario y secundario, desde la perspectiva del titular y del responsable.	Guía SPDP
RF05	Estimar la probabilidad referida a un lapso anual y el impacto, con justificación documentada de cada valor.	Guía SPDP
RF06	Modelar por separado la confidencialidad, la integridad y la disponibilidad, además de la licitud del tratamiento.	Guía SPDP; LOPDP art. 37
RF07	Ponderar el impacto con los criterios de categorías especiales, grupos vulnerables, número de titulares, naturaleza de la vulneración y volumen de datos.	LOPDP arts. 25 y 40; guía SPDP
RF08	Determinar el nivel de riesgo inherente y residual con una regla explícita para los escenarios de baja probabilidad y muy alto impacto.	Guía SPDP
RF09	Determinar la necesidad de una evaluación de impacto (EIPD) a partir de las etapas previas.	LOPDP art. 42; Res. SPDP-SPD-2026-0005-R
RF10	Seleccionar opciones de tratamiento (mitigar, transferir, evitar, aceptar) y controles con responsable, plazo e indicador.	LOPDP art. 37; ISO/IEC 27005
RF11	Definir indicadores de monitoreo y un procedimiento de respuesta que permita notificar vulneraciones en el término legal.	LOPDP arts. 37 y 43

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [10, 14, 15, 41]

2.5.2 Requerimientos No Funcionales

La Tabla 11 presenta los requisitos no funcionales.

Tabla 11: Requisitos no funcionales de la metodología.

ID	Atributo	Descripción
RNF01	Trazabilidad	Cada actividad y cada campo de la matriz se vinculan con un objetivo específico, una etapa de la guía de la SPDP y un artículo de la LOPDP.
RNF02	Reutilización	La matriz se entrega como plantilla de hoja de cálculo con listas desplegables, fórmulas y formato condicional, aplicable a otros procesos de la institución.
RNF03	Usabilidad	La metodología puede ser aplicada por personal de TI, jurídico o de gestión sin formación especializada en análisis cuantitativo de riesgos.
RNF04	Escalabilidad	Puede aplicarse a un proceso, a una unidad o a toda la institución sin cambiar su estructura.
RNF05	Bajo costo	Se apoya en normas de acceso público y en herramientas ofimáticas de uso común.
RNF06	Confidencialidad	Los expedientes de aplicación usan datos seudonimizados o agregados y registran el acceso a la evidencia.
RNF07	Mantenibilidad	Las escalas, catálogos y criterios se mantienen en hojas separadas para actualizarlos ante cambios normativos.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

2.6 Diseño de la Solución

2.6.1 Estructura general de la metodología

La metodología propuesta se compone de una fase de diagnóstico de madurez (fase 0) y de las cuatro fases definidas en el objetivo específico 2: identificación, evaluación, mitigación y monitoreo. Las fases se articulan con las etapas obligatorias de la guía de la SPDP, que a su vez sigue el proceso de ISO/IEC 27005:2022 [14, 41], y se apoyan en dos actividades transversales: la comunicación y consulta con las partes interesadas, y el registro documental de cada decisión y de su justificación. La Figura 2 representa esta estructura.

La Tabla 12 detalla, para cada fase, las actividades principales, los productos, la etapa correspondiente de la guía de la SPDP y el fundamento en la LOPDP. Este detalle se desarrollará y aplicará al caso simulado en el Capítulo III.

2.6.2 Modelo de estimación del riesgo

El modelo de estimación respeta las reglas de la guía de la SPDP: cada escenario se analiza por separado para la confidencialidad, la integridad, la disponibilidad y la licitud; la probabilidad se refiere a un lapso anual; cada valor se acompaña de su justificación, y las escalas se tratan como etiquetas ordinales, no como magnitudes que puedan multiplicarse [14]. Las escalas que se proponen a continuación constituyen

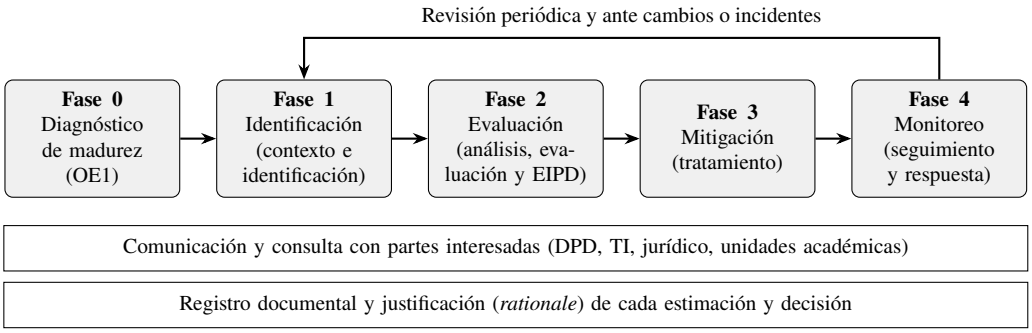


Figura 2: Estructura de la metodología propuesta.
Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [14, 41]

Tabla 12: Fases, actividades y productos de la metodología.

Fase	**Actividades principales**	**Productos**	**Etapa SPDP / LOPDP**
0. Diagnóstico de madurez	Definir alcance; aplicar el cuestionario de madurez; revisar documentos y práctica efectiva; entrevistar a responsables.	Informe de madurez; RAT preliminar; brechas prioritarias	Previa al contexto / art. 37
1. Identificación	Establecer el contexto interno, externo y normativo; completar el RAT; identificar activos, amenazas y vulnerabilidades de los cuatro tipos; construir escenarios de riesgo.	RAT; catálogo de amenazas y vulnerabilidades; escenarios de riesgo	Contexto e identificación / arts. 25 y 40
2. Evaluación	Estimar probabilidad anual e impacto con justificación (Delphi); determinar el nivel inherente; contrastar con los criterios de aceptación; decidir si se requiere EIPD.	Matriz de riesgo inherente; mapa de calor; dictamen de EIPD	Análisis y evaluación / arts. 40 y 42
3. Mitigación	Elegir la opción de tratamiento; seleccionar controles jurídicos, organizacionales y técnicos; estimar el riesgo residual; aprobar el riesgo residual.	Plan de tratamiento; matriz de riesgo residual	Tratamiento / art. 37
4. Monitoreo	Definir indicadores; revisar periódicamente los escenarios; gestionar y notificar vulneraciones; actualizar la matriz y retroalimentar la fase 1.	Tablero de indicadores; procedimiento de respuesta; registro de revisiones	Monitoreo y comunicación / arts. 37 y 43

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [10, 14, 41]

la versión inicial que el panel Delphi revisará y calibrará.

La Tabla 13 define la escala de probabilidad. Cada nivel se asocia con un intervalo de frecuencia anual esperada, lo que obliga a que la estimación tenga un referente verificable y permite contrastarla en el futuro con el registro de incidentes.

Tabla 13: Escala de probabilidad (lapso anual).

Nivel	**Frecuencia anual esperada**	**Descripción orientativa**
Muy baja	Menos de una vez cada 10 años	No hay antecedentes en la institución ni en el sector; la amenaza requiere capacidades poco comunes.
Baja	Una vez cada 2 a 10 años	Hay antecedentes en el sector, pero los controles existentes dificultan su materialización.
Media	Aproximadamente una vez cada 1 a 2 años	Hay antecedentes en IES similares y controles parciales.
Alta	Entre 1 y 5 veces por año	El evento ha ocurrido en la institución o la vulnerabilidad es conocida y explotable.
Muy alta	Más de 5 veces por año	El evento es recurrente o la vulnerabilidad se explota con facilidad.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [14]

El impacto se valora en primer lugar desde la perspectiva del titular, conforme al enfoque de derechos de la LOPDP, y en segundo lugar desde la del responsable (sanciones, costos y reputación). La Tabla 14 define la escala de impacto sobre el titular, adaptada de los niveles de severidad propuestos por ENISA [39].

El nivel de impacto inicial se ajusta con los criterios agravantes que exige la guía de la SPDP [14]: (a) si el escenario involucra categorías especiales de datos o datos de grupos vulnerables, en particular de adolescentes [10, art. 25], el impacto sube un nivel; (b) si el número de titulares afectados supera el umbral que la institución defina como masivo, el impacto sube un nivel; (c) si la vulneración es intencional o los datos pueden combinarse para identificar a los titulares con facilidad, el impacto sube un nivel. El ajuste acumulado no puede superar el nivel muy alto y cada ajuste debe justificarse.

2.6.3 Determinación del nivel de riesgo y criterios de aceptación

Para evitar que el nivel de riesgo se obtenga multiplicando etiquetas, práctica que la guía de la SPDP desaconseja [14], el nivel se asigna mediante una tabla de decisión (Tabla 15). La tabla otorga mayor peso al impacto que a la probabilidad y

Tabla 14: Escala de impacto sobre el titular.

Nivel	Consecuencias para el titular
Muy bajo	Molestias menores que el titular supera sin dificultad (por ejemplo, reingresar información).
Bajo	Inconvenientes que el titular supera con algún esfuerzo (costos menores, tiempo, molestias).
Medio	Consecuencias significativas que el titular puede superar con dificultad (pérdida de oportunidades académicas, cargos indebidos reversibles, temor o estrés).
Alto	Consecuencias graves, difíciles de superar (fraude o suplantación de identidad, discriminación, exclusión de beneficios, daño reputacional).
Muy alto	Consecuencias irreversibles o que afectan derechos fundamentales, la salud o la integridad del titular (exposición de datos de salud o discapacidad, afectación a menores de edad).

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia adaptada de [39]

contiene una regla explícita para los escenarios de baja probabilidad y alto impacto: todo escenario con impacto muy alto sobre el titular se clasifica, como mínimo, en nivel alto, con independencia de su probabilidad. El mapa de calor resultante se utiliza solo para representar los resultados, no para calibrarlos.

Tabla 15: Tabla de decisión del nivel de riesgo.

Probabilidad / Impacto	Muy bajo	Bajo	Medio	Alto	Muy alto
Muy alta	Medio	Alto	Alto	Muy alto	Muy alto
Alta	Bajo	Medio	Alto	Muy alto	Muy alto
Media	Bajo	Medio	Medio	Alto	Muy alto
Baja	Muy bajo	Bajo	Medio	Alto	Alto
Muy baja	Muy bajo	Muy bajo	Bajo	Medio	Alto

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [14]

Los criterios de aceptación del riesgo son los siguientes. Los riesgos de nivel muy bajo y bajo pueden aceptarse, con registro de la decisión y monitoreo periódico. Los riesgos de nivel medio deben tratarse dentro del plan anual, salvo que la dirección acepte formalmente el riesgo con la justificación correspondiente. Los riesgos de nivel alto y muy alto deben tratarse con prioridad y, cuando afecten a categorías especiales de datos o a tratamientos a gran escala, activan la realización de una EIPD [10, art. 42]. Ningún riesgo con impacto muy alto sobre el titular puede aceptarse sin las observaciones previas del delegado de protección de datos y del área jurídica

y sin aprobación de la máxima autoridad.

2.6.4 Estructura de la matriz de riesgos

La matriz de riesgos se implementa como una hoja de cálculo con una fila por escenario y por dimensión (confidencialidad, integridad, disponibilidad o licitud). Sus campos se agrupan en seis bloques, que se resumen en la Tabla 16. Hojas adicionales contienen las escalas de probabilidad e impacto, la tabla de decisión, los criterios de aceptación, el catálogo de amenazas, el catálogo de controles referidos a ISO/IEC 27002:2022 [49], los resultados del panel Delphi y el cálculo del puntaje de Brier.

Tabla 16: Bloques de campos de la matriz de riesgos.

Bloque	**Campos**
Identificación del tratamiento	ID, subproceso, actividad de tratamiento, categorías de datos, categoría especial (sí/no), tipo y número estimado de titulares, grupo vulnerable, activo o sistema
Escenario de riesgo	Dimensión (C/I/D/licitud), comunidad de amenaza, vector, vulnerabilidad y su tipo (jurídica, organizacional, técnica, titulares), artículo de la LOPDP o norma de la SPDP, control existente
Riesgo inherente	Probabilidad anual y su justificación; impacto sobre el titular, impacto sobre el responsable y su justificación; agravantes aplicados; nivel inherente
Tratamiento	Opción (mitigar, transferir, evitar, aceptar), control propuesto con referencia a ISO/IEC 27002, responsable, plazo
Riesgo residual	Probabilidad residual, impacto residual, nivel residual, aceptación
Monitoreo	Indicador, frecuencia de revisión, estado, fecha de la última revisión

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

2.7 Justificación Técnica

La selección de los componentes de la metodología responde a cinco decisiones.

Marco de proceso. Se adoptan las etapas de la guía de la SPDP, alineadas con ISO/IEC 27005:2022, porque la guía es la referencia normativa vigente en Ecuador y su capítulo I es de cumplimiento obligatorio [12, 14]; ISO/IEC 27005 aporta el detalle operativo del proceso y facilita la integración con un sistema de gestión de seguridad de la información [41]. Se descartó adoptar un marco extranjero completo, como el de la AEPD o el NIST Privacy Framework, porque ninguno responde a la LOPDP y su adaptación exigiría el mismo esfuerzo que construir la metodología sobre la guía nacional [37, 38].

Enfoque centrado en el titular. A diferencia de los modelos aplicados en el

sector público y educativo ecuatoriano, centrados en activos [29, 21], la escala de impacto principal se refiere al daño al titular. La literatura reciente respalda incorporar categorías de daño a la privacidad en las evaluaciones de riesgo [27].

Estimación cualitativa calibrada. Los modelos cuantitativos como FAIR requieren datos de frecuencia y pérdidas que una IES rara vez posee [28]. Por ello se opta por escalas ordinales ancladas en frecuencias anuales, estimadas mediante un panel Delphi y validadas con el puntaje de Brier, opción que la propia guía de la SPDP admite cuando se documenta la justificación de cada valor [14]. La estructura de la matriz permite migrar a estimaciones cuantitativas cuando la institución acumule datos históricos.

Herramienta de soporte. La matriz se implementa en una hoja de cálculo, compatible con Microsoft Excel y LibreOffice Calc, en lugar de una plataforma comercial de gobierno, riesgo y cumplimiento. Esta decisión reduce el costo de adopción, facilita la revisión por parte de unidades no técnicas y cumple los requisitos de reutilización y mantenibilidad (RNF02, RNF05 y RNF07).

Marco de investigación. La ciencia del diseño es el paradigma adecuado porque el resultado es un artefacto cuya utilidad debe demostrarse y evaluarse [45]; el proceso de Peffers et al. [46] ofrece una secuencia verificable que coincide con las fases de la investigación declaradas en la propuesta.

CAPÍTULO III

IMPLEMENTACIÓN, PRUEBAS Y RESULTADOS

Este capítulo presenta la aplicación de la metodología diseñada en el Capítulo II al caso simulado del proceso de admisión y matrícula de la IES-S. Se describen los productos obtenidos en cada fase, las pruebas realizadas sobre la plantilla y sobre el cumplimiento de los requisitos, y los resultados comparados entre la situación inicial y la situación proyectada tras el tratamiento.

Debe advertirse una condición que atraviesa todo el capítulo: las probabilidades y los impactos registrados son **estimaciones preliminares del investigador**, cada una acompañada de su justificación, elaboradas para demostrar el funcionamiento de la metodología. Conforme a la Sección 2.5, estas estimaciones deberán ser revisadas y calibradas por el panel Delphi; los resultados de ese panel y de la validación con expertos se incorporarán cuando concluya su aplicación.

3.1 Descripción de la Solución

La solución implementada es un artefacto metodológico compuesto por cuatro productos:

1. **Documento metodológico**: fases 0 a 4, escalas, tabla de decisión y criterios de aceptación (Sección 2.6).
2. **Plantilla reutilizable de matriz de riesgos**: archivo `matriz/Plantilla_Matriz_Riesgos_LO` con diez hojas, listas desplegables, fórmulas y formato condicional (Anexo H).
3. **Instrumentos de recolección**: lista de verificación normativa, guía de entrevista, cuestionario de madurez, cuestionario Delphi, afirmaciones de calibración, instrumento de validación y consentimiento informado (Anexos A a G).
4. **Matriz aplicada al caso simulado**: archivo `matriz/Matriz_Aplicada_IES-S.xlsx`, con trece escenarios de riesgo del proceso de admisión y matrícula.

La plantilla y la matriz aplicada se generan mediante un programa en JavaScript (`scripts/build_matriz.js`) que construye el libro de cálculo, evalúa todas sus

fórmulas con un motor de cálculo independiente y reporta los resultados. De este modo, las cifras que se presentan en este capítulo proceden directamente de las fórmulas de la matriz y no de cálculos manuales.

3.2 Proceso de Implementación

3.2.1 Fase 0: diagnóstico de madurez

El cuestionario de madurez (Anexo C) y la lista de verificación normativa (Anexo A) se aplicaron sobre la documentación y las prácticas del caso simulado descritas en la Sección 2.1. La Tabla 17 resume el nivel de madurez por dominio, calculado como la mediana de sus enunciados.

Tabla 17: Nivel de madurez por dominio en la IES-S (caso simulado).

Dominio	Respuestas	Nivel	Hallazgo principal
Gobernanza	2, 1, 1	1	Política general sin delegado de protección de datos designado.
Inventario y licitud	1, 2, 1	1	Sin RAT; consentimiento genérico en el formulario de postulación.
Gestión de riesgos	1, 1, 1	1	No se evalúan riesgos para los titulares ni la necesidad de EIPD.
Seguridad	2, 3, 2	2	Respaldos diarios, pero accesos por unidad y sin registro de accesos a datos sensibles.
Terceros	1, 1	1	Contratos con encargados sin cláusulas de protección de datos.
Ciclo de vida	1, 1	1	Conservación indefinida de expedientes.
Derechos e incidentes	2, 1	1,5	Solicitudes atendidas de manera informal; sin procedimiento de notificación.
Cultura	2, 1	1,5	Inducción general sin contenidos de protección de datos.
Nivel global (mediana)		**1**	**Inicial**

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Aplicación del Anexo C al caso simulado

La lista de verificación normativa arrojó cero requisitos cumplidos, cinco cumplidos parcialmente (bases de legitimación, información al titular, medidas de seguridad, atención de derechos y capacitación) y diez incumplidos. Entre los incumplimientos destacan la ausencia de una metodología de análisis de riesgos, que la LOPDP tipifica como infracción grave [10, art. 68], la falta de un procedimiento de notificación de vulneraciones [10, art. 43] y la inexistencia de un dictamen sobre tratamiento a gran escala. El nivel global *inicial* confirma que la institución debe comenzar por las fases de identificación y evaluación antes de abordar controles avanzados.

3.2.2 Fase 1: identificación

Establecimiento del contexto. En el contexto interno, el proceso involucra a cinco unidades y a cuatro encargados del tratamiento, y se concentra en dos ventanas anuales de alta carga operativa. En el contexto externo, el sector educativo presenta una elevada exposición al *ransomware* [1] y antecedentes regionales de exfiltración de datos de estudiantes [7, 6]. En el contexto normativo, rigen la LOPDP, su reglamento, la guía de gestión de riesgos de la SPDP y la norma de tratamiento a gran escala [10, 11, 14, 15].

Registro de actividades de tratamiento. La Tabla 18 presenta el RAT preliminar del proceso, construido a partir de las entrevistas y de la revisión documental del caso.

Tabla 18: Registro de actividades de tratamiento (RAT) preliminar del proceso de admisión y matrícula.

Subproceso	**Finalidad**	**Base de legitimación (propuesta)**	**Categorías especiales**	**Encargados**	**Conservación actual**
SP1 Registro y postulación	Gestionar la postulación del aspirante	Medidas precontractuales; consentimiento para difusión	Datos de adolescentes	CRM de admisiones	Indefinida
SP2 Admisión y nivelación	Evaluar y decidir la admisión	Medidas precontractuales	Datos de adolescentes	Suite en la nube	Indefinida
SP3 Becas y aranceles	Asignar becas y aranceles diferenciados	Consentimiento explícito; obligación normativa	Discapacidad, salud, condición socioeconómica	Suite en la nube	Indefinida
SP4 Pago de matrícula	Cobrar y facturar	Ejecución del contrato; obligación tributaria	Ninguna	Pasarela de pagos	Según normativa tributaria
SP5 Legalización	Formalizar la matrícula y crear cuentas	Ejecución del contrato	Ninguna	Suite en la nube; LMS	Mientras dure la relación académica
SP6 Reportes y archivo	Reportar a organismos de control y archivar	Obligación legal	Según el reporte	Ninguno	Indefinida (incluye no admitidos)

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia (caso simulado)

Determinación de gran escala. El proceso trata de forma sistemática datos de adolescentes en un entorno educativo (SP1 y SP2) y datos de salud y discapacidad (SP3). Ambos supuestos constituyen, de forma directa, tratamiento a gran escala según la Resolución SPDP-SPD-2026-0005-R, lo que vuelve obligatorias la evaluación de impacto previa y la designación de un delegado de protección de datos [15, arts. 12 y 14]. Esta conclusión, obtenida en la fase de identificación, condiciona el

resto de la aplicación: la EIPD no es opcional para la IES-S.

Escenarios de riesgo. A partir del catálogo de amenazas de la plantilla y de las vulnerabilidades halladas en la fase 0, se construyeron trece escenarios de riesgo, cada uno referido a una sola dimensión. La Tabla 19 los resume; la descripción completa de cada escenario (comunidad de amenaza, vector, vulnerabilidad, control existente y fundamento normativo) consta en la matriz aplicada.

Tabla 19: Escenarios de riesgo identificados en el proceso de admisión y matrícula.

ID	SP	Escenario	Dimensión	Tipo de vulnerabilidad
R-01	SP3	Exposición de certificados de discapacidad y fichas socioeconómicas por carpetas compartidas sin restricción	Confidencialidad	Organizacional
R-02	SP1	Compromiso de cuentas del personal de admisiones por *phishing* y acceso al CRM	Confidencialidad	Técnica
R-03	SP2	Publicación de listados de admitidos con cédula y puntaje	Licitud	Organizacional
R-04	SP1	Uso de datos de aspirantes para difusión sin consentimiento específico	Licitud	Jurídica
R-05	SP5	Consultas indebidas al SGA por privilegios excesivos	Confidencialidad	Organizacional
R-06	SP2	Alteración de resultados de admisión mediante una cuenta privilegiada comprometida	Integridad	Técnica
R-07	SP4	Tratamiento por la pasarela de pagos sin garantías contractuales	Confidencialidad	Jurídica
R-08	SP5	Interrupción del SGA por *ransomware* durante la matrícula	Disponibilidad	Técnica
R-09	SP3	Exfiltración de expedientes de becas en un ataque de doble extorsión	Confidencialidad	Técnica
R-10	SP6	Conservación indefinida de expedientes de aspirantes no admitidos	Licitud	Jurídica
R-11	SP3	Transferencia internacional a la nube sin evaluación de garantías	Licitud	Jurídica
R-12	SP6	Vulneración no notificada dentro del término legal	Licitud	Organizacional
R-13	SP1	Indisponibilidad del portal en el cierre de postulaciones	Disponibilidad	Técnica

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Matriz aplicada al caso simulado IES-S

Los escenarios cubren las cuatro dimensiones y los cuatro tipos de vulnerabilidad previstos por la guía de la SPDP [14]: cinco escenarios se originan en vulnerabilidades técnicas, cuatro en jurídicas y cuatro en organizacionales, mientras que la condición de grupo vulnerable de los titulares —adolescentes y personas con discapacidad— está presente en ocho de ellos.

3.2.3 Fase 2: evaluación

Para cada escenario se estimó la probabilidad anual y el impacto sobre el titular con la escala de la Sección 2.6, se aplicaron los agravantes y la matriz determinó el impacto ajustado y el nivel inherente mediante la tabla de decisión. La Tabla 20 presenta los resultados.

Once de los trece escenarios (84,6 %) alcanzan un nivel inherente alto o muy alto. Cuatro de ellos son de nivel muy alto: la exposición y la exfiltración de datos de becas

Tabla 20: Riesgo inherente de los escenarios del caso simulado.

ID	Probabilidad	Impacto (titular)	Agravantes	Impacto ajustado	Nivel inherente	EIPD
R-01	Media	Alto	1	Muy alto	Muy alto	Obligatoria
R-02	Alta	Medio	1	Alto	Muy alto	Obligatoria
R-03	Media	Medio	1	Alto	Alto	Obligatoria
R-04	Muy alta	Bajo	1	Medio	Alto	Obligatoria
R-05	Alta	Medio	0	Medio	Alto	Valorar
R-06	Baja	Alto	0	Alto	Alto	Obligatoria
R-07	Baja	Alto	0	Alto	Alto	Valorar
R-08	Media	Alto	1	Muy alto	Muy alto	Valorar
R-09	Media	Alto	2	Muy alto	Muy alto	Obligatoria
R-10	Muy alta	Bajo	1	Medio	Alto	Valorar
R-11	Media	Medio	1	Alto	Alto	Obligatoria
R-12	Media	Medio	0	Medio	Medio	Recomendada
R-13	Media	Bajo	0	Bajo	Medio	Recomendada

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Matriz aplicada al caso simulado IES-S (estimaciones preliminares)

(R-01 y R-09), el compromiso de cuentas de admisiones (R-02) y la interrupción del SGA por *ransomware* (R-08). La Figura 3 representa la distribución de los escenarios en el mapa de calor; conforme a la guía de la SPDP, el mapa se usa para comunicar los resultados y no para calibrarlos [14].

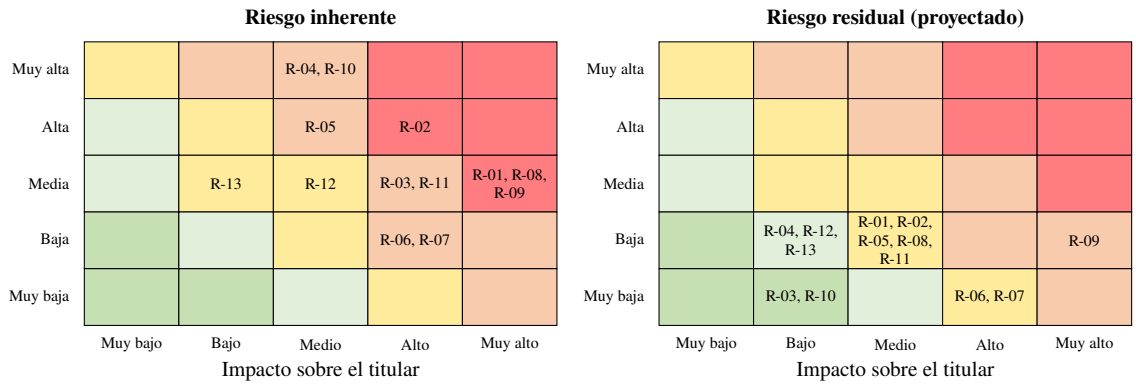


Figura 3: Mapas de calor del riesgo inherente y residual del caso simulado.
Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Matriz aplicada al caso simulado IES-S

Dictamen de evaluación de impacto. Además de ser obligatoria por la calificación de gran escala, la EIPD se justifica por el resultado de la evaluación: siete escenarios de nivel alto o muy alto involucran categorías especiales de datos o titulares de grupos vulnerables. El subproceso SP3 (becas y aranceles diferenciados) concentra los escenarios más graves (R-01, R-09 y R-11), por lo que se priorizó para la EIPD. La Tabla 21 resume sus elementos principales.

Tabla 21: Síntesis de la EIPD del subproceso de becas y aranceles diferenciados (SP3).

Elemento	Contenido
Descripción del tratamiento	Recolección, verificación y conservación de fichas socioeconómicas y certificados de discapacidad de aproximadamente 1 200 postulantes por año, para asignar becas y aranceles diferenciados.
Necesidad y proporcionalidad	La condición socioeconómica y la discapacidad son necesarias para asignar el beneficio; no lo es conservar copia del certificado una vez verificado ni mantener los expedientes de postulantes sin beca.
Riesgos para los titulares	Discriminación y exclusión de beneficios por exposición (R-01, R-09); pérdida de control por transferencias sin garantías (R-11).
Medidas previstas	Minimización (registrar solo la verificación), clasificación y control de acceso, autenticación multifactor, cifrado en reposo, prevención de fuga, evaluación de la transferencia y cláusulas con el proveedor.
Riesgo residual	Medio en R-01 y R-11; alto en R-09, porque el impacto sobre el titular se mantiene muy alto aunque disminuya la probabilidad.
Conclusión	El tratamiento puede continuar si se implementan las medidas previstas; el riesgo residual de R-09 requiere las observaciones del delegado de protección de datos y del área jurídica y la aprobación de la máxima autoridad, y debe considerarse la eliminación de los certificados tras su verificación para reducir el impacto.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [10, 14, 36]

3.2.4 Fase 3: mitigación

Para cada escenario se eligió una opción de tratamiento, se propusieron controles con referencia a ISO/IEC 27002:2022 [49] y se estimó el riesgo residual bajo el supuesto de que los controles se implementen. La Tabla 22 presenta el plan de tratamiento. Conforme a las exclusiones del proyecto, la implementación de estas medidas corresponde a la institución.

Tras el tratamiento proyectado, solo el escenario R-09 conserva un nivel alto. Este resultado ilustra la regla de la tabla de decisión para los escenarios de alto impacto: aunque los controles reducen la probabilidad de exfiltración a baja, el daño potencial sobre titulares con discapacidad sigue siendo muy alto, por lo que el riesgo no desciende de nivel alto y no puede aceptarse sin las observaciones del delegado de protección de datos y del área jurídica y la aprobación de la máxima autoridad. La única forma de reducirlo es actuar sobre el impacto, por ejemplo eliminando los certificados una vez verificados. Los escenarios R-06 y R-07 muestran el caso contrario: con impacto alto y probabilidad muy baja, el riesgo residual queda en nivel medio y debe tratarse dentro del plan anual.

Tabla 22: Plan de tratamiento y riesgo residual proyectado.

ID	Opción	Controles principales (ISO/IEC 27002:2022)	Plazo	Prob. res.	Imp. res.	Nivel residual
R-01	Mitigar	5.12 clasificación; 5.15 control de acceso; 8.5 MFA; 8.12 prevención de fuga; minimización	3 meses	Baja	Medio	Medio
R-02	Mitigar	8.5 MFA; 6.3 concienciación; 5.18 revisión de accesos; minimización del formulario	2 meses	Baja	Medio	Medio
R-03	Evitar	8.11 enmascaramiento: publicar solo el código de postulante	Próximo periodo	Muy baja	Bajo	Muy bajo
R-04	Mitigar	5.34 consentimiento por finalidad y aviso de privacidad; 5.31 requisitos legales	1 mes	Baja	Bajo	Bajo
R-05	Mitigar	5.15 acceso por función; 5.18 revisión por periodo; 8.15 registro de accesos	4 meses	Baja	Medio	Medio
R-06	Mitigar	8.2 cuentas privilegiadas nominativas; 8.5 MFA; 8.15 registro de cambios	3 meses	Muy baja	Alto	Medio
R-07	Transferir	5.19 y 5.20 cláusulas de protección de datos y notificación de incidentes	6 meses	Muy baja	Alto	Medio
R-08	Mitigar	8.13 respaldos aislados y probados; 8.8 vulnerabilidades; 8.7 malware; 5.24 y 5.26 incidentes	4 meses	Baja	Medio	Medio
R-09	Mitigar	8.24 cifrado en reposo; 8.12 prevención de fuga; 8.16 monitoreo; 8.10 eliminación	6 meses	Baja	Muy alto	Alto
R-10	Mitigar	8.10 eliminación periódica según tabla de conservación; 5.9 inventario	6 meses	Muy baja	Bajo	Muy bajo
R-11	Mitigar	5.19 y 5.20 acuerdos con el proveedor; 5.31 evaluación de la transferencia	4 meses	Baja	Medio	Medio
R-12	Mitigar	5.24 y 5.26 procedimiento de respuesta y notificación; simulacro anual	2 meses	Baja	Bajo	Bajo
R-13	Mitigar	8.6 gestión de la capacidad; acuerdo de nivel de servicio	Próximo periodo	Baja	Bajo	Bajo

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Matriz aplicada al caso simulado IES-S

3.2.5 Fase 4: monitoreo

La Tabla 23 define los indicadores de monitoreo asociados a los escenarios de mayor nivel, junto con su meta y su frecuencia de revisión.

Tabla 23: Indicadores de monitoreo del riesgo.

Escenarios	Indicador	Meta	Frecuencia
R-01	Enlaces públicos detectados en carpetas restringidas	0	Mensual
R-02, R-06	Porcentaje de cuentas con autenticación multifactor	100 %	Mensual
R-02	Tasa de clics en simulaciones de *phishing*	< 5 %	Por periodo de admisión
R-05	Porcentaje de perfiles revisados al cierre de cada periodo	100 %	Por periodo académico
R-07, R-11	Porcentaje de encargados con cláusulas de protección de datos	100 %	Semestral
R-08	Tiempo de restauración en la prueba de respaldo	< 24 h	Trimestral
R-09	Porcentaje de repositorios sensibles cifrados	100 %	Trimestral
R-10	Expedientes vencidos sin eliminar	0	Semestral
R-12	Vulneraciones notificadas dentro del término legal	100 %	Por incidente; simulacro anual

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Matriz aplicada al caso simulado IES-S

El procedimiento de respuesta a vulneraciones, que atiende el escenario R-12, se estructura en cinco pasos: (1) detección y registro del incidente; (2) contención y evaluación inicial, en las primeras 24 horas, para determinar si hay datos personales afectados; (3) valoración del riesgo para los titulares con las escalas de la metodología; (4) notificación a la SPDP dentro del término de cinco días previsto en el artículo 43 de la LOPDP [10, art. 43] y comunicación a los titulares cuando corresponda, y (5) análisis posterior, actualización de la matriz y retroalimentación a la fase de identificación. La matriz se revisa, además, al cierre de cada periodo de admisión y ante cualquier cambio relevante de sistemas, proveedores o normativa.

3.3 Pruebas y Validación

3.3.1 Verificación de la plantilla de matriz

Las fórmulas de la plantilla se evaluaron con un motor de cálculo independiente (HyperFormula) en el momento de generar cada archivo. La plantilla y la matriz aplicada contienen 1 057 fórmulas cada una y ninguna produjo errores; las cuatro celdas que emplean la función `QUARTILE`, que ese motor no implementa, se verificaron con un cálculo equivalente en JavaScript. Además, se diseñaron seis casos de prueba para comprobar las reglas de decisión de la metodología. La Tabla 24

muestra que todos produjeron el resultado esperado.

Tabla 24: Casos de prueba de las reglas de decisión de la plantilla.

Caso	Regla verificada	Entrada	Resultado obtenido	Estado
T-01	Impacto muy alto con probabilidad muy baja no desciende de nivel alto	P = Muy baja; I = Muy alto	Nivel inherente: Alto	Correcto
T-02	Probabilidad muy alta con impacto muy bajo no se trata como riesgo alto	P = Muy alta; I = Muy bajo	Nivel inherente: Medio	Correcto
T-03	Los agravantes no superan el nivel muy alto	I = Alto; 3 agravantes	Impacto ajustado: Muy alto	Correcto
T-04	Una fila incompleta no genera nivel ni errores	Sin probabilidad	Celdas de resultado vacías	Correcto
T-05	Riesgo residual alto sin categoría especial no es aceptable	PR = Media; IR = Alto	Nivel residual: Alto; “No aceptable: tratamiento prioritario”	Correcto
T-06	Impacto residual muy alto exige aprobación reforzada	PR = Muy baja; IR = Muy alto	Nivel residual: Alto; requiere DPD/jurídico y máxima autoridad	Correcto

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Ejecución de `scripts/build_matriz.js` con los casos de prueba

3.3.2 Verificación del cumplimiento de los requisitos

La Tabla 25 contrasta los requisitos funcionales de la Sección 2.5 con la evidencia generada en la aplicación al caso simulado.

Tabla 25: Verificación de los requisitos funcionales en el caso simulado.

Requisito	Evidencia en la aplicación	Estado
RF01	Diagnóstico de madurez por dominio (Tabla 17)	Cumple
RF02	RAT preliminar de seis subprocesos (Tabla 18)	Cumple
RF03	Vulnerabilidades jurídicas, organizacionales, técnicas y de grupos vulnerables (Tabla 19)	Cumple
RF04	Trece escenarios con comunidad de amenaza, vector, vulnerabilidad e impacto en el titular y en el responsable (matriz aplicada)	Cumple
RF05	Probabilidad anual con justificación en cada escenario	Cumple (pendiente calibración Delphi)
RF06	Escenarios separados por confidencialidad, integridad, disponibilidad y licitud	Cumple
RF07	Agravantes aplicados y justificados en ocho escenarios	Cumple
RF08	Nivel inherente y residual por tabla de decisión; regla de alto impacto verificada (T-01, T-06, R-09)	Cumple
RF09	Determinación de gran escala y dictamen de EIPD (Tabla 21)	Cumple
RF10	Plan de tratamiento con opción, controles, responsable y plazo (Tabla 22)	Cumple
RF11	Indicadores y procedimiento de respuesta a vulneraciones (Tabla 23)	Cumple

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

3.3.3 Validación con expertos

La validación de la metodología se realiza con el panel de expertos descrito en el Capítulo II, en dos momentos: (a) la calibración de los expertos con las afirmaciones del Anexo E y la estimación Delphi de la probabilidad y el impacto de los trece escenarios (Anexo D), cuyos resultados reemplazarán las estimaciones preliminares, y (b) la valoración de la metodología con el instrumento del Anexo F, en el que un criterio se considera validado cuando la mediana del panel es igual o mayor que 4.

[PENDIENTE: resultados de la calibración (puntaje de Brier por experto), de las rondas Delphi (mediana, RIC y consenso por escenario) y de la validación por juicio de expertos (mediana por criterio V01–V12 y observaciones). Se incorporarán al concluir la aplicación de los instrumentos con el panel.]

3.4 Resultados

La Tabla 26 compara la situación inicial del caso simulado con la situación proyectada tras la aplicación de la metodología y la implementación del plan de tratamiento.

Tabla 26: Comparación de la situación inicial y la proyectada en el caso simulado.

Indicador	Inicial	Proyectado
Escenarios de nivel muy alto	4	0
Escenarios de nivel alto	7	1
Escenarios de nivel medio	2	7
Escenarios de nivel bajo o muy bajo	0	5
Escenarios de nivel alto o muy alto (%)	84,6 %	7,7 %
Escenarios con riesgo aceptable sin condiciones	0	5
Actividades de tratamiento inventariadas (RAT)	0	6
Dictamen de gran escala y EIPD	No	Sí

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Matriz aplicada al caso simulado IES-S

La reducción de los escenarios de nivel alto o muy alto se calcula con la Ecuación 2:

$$\text{Reducción (\%)} = \frac{N_{\text{inicial}} - N_{\text{proyectado}}}{N_{\text{inicial}}} \times 100 = \frac{11 - 1}{11} \times 100 = 90{,}9\,\% \qquad (2)$$

Estos resultados deben interpretarse con dos cautelas. Primero, el riesgo residual

es *proyectado*: supone que los controles propuestos se implementan con eficacia, lo que excede el alcance del proyecto. Segundo, las estimaciones son preliminares y pueden variar tras la calibración con el panel Delphi. Aun así, la aplicación demuestra que la metodología permite pasar de una situación sin inventario, sin evaluación de riesgos y sin dictamen de EIPD a un conjunto trazable de escenarios priorizados, con controles, responsables, plazos e indicadores, que es precisamente la evidencia de responsabilidad proactiva que exigen los artículos 37, 40 y 42 de la LOPDP [10].

3.5 Cronograma y Presupuesto

3.5.1 Cronograma

El proyecto se ejecuta en 24 semanas, distribuidas en las cinco fases de la investigación. La Figura 4 presenta el cronograma.

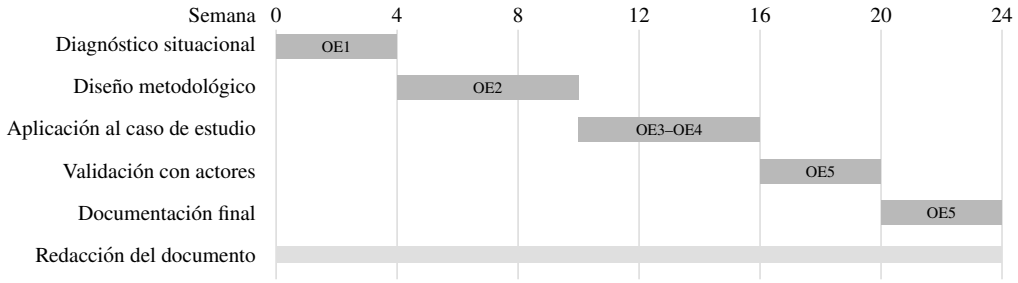


Figura 4: Cronograma del proyecto.
Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

3.5.2 Presupuesto

La Tabla 27 presenta el presupuesto referencial del proyecto. El componente principal es el tiempo del investigador, valorado como costo de oportunidad; el software empleado es libre o se dispone mediante licencias institucionales. El costo de las normas ISO/IEC depende de si se accede a ellas mediante la biblioteca institucional o se adquieren; por ello no se incluye en el subtotal.

Tabla 27: Presupuesto referencial del proyecto (USD).

Rubro	**Cantidad**	**Costo unitario**	**Total**
Tiempo del investigador (costo de oportunidad)	960 h	5,00	4 800,00
Equipo de cómputo propio (depreciación de 6 meses)	1	100,00	100,00
Software: LaTeX (MiKTeX), Node.js, hoja de cálculo	–	0,00	0,00
Normas ISO/IEC 27005, 27002 y 29134	3	[VERIFICAR]	[VERIFICAR]
Internet y energía	6 meses	30,00	180,00
Impresión y empastado	1	60,00	60,00
Subtotal			**5 140,00**
Imprevistos (5 %)			257,00
Total referencial			**5 397,00**

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia (valores referenciales)

CAPÍTULO IV

CONCLUSIONES Y RECOMENDACIONES

4.1 Conclusiones

[Redactar conclusiones basadas en los resultados obtenidos y en el cumplimiento de los objetivos planteados.]

4.2 Recomendaciones

[Proponer mejoras, optimizaciones o ampliaciones del proyecto, fundamentadas en el análisis realizado.]

4.3 Trabajos Futuros

[Plantear líneas de desarrollo o investigación que puedan derivarse del proyecto implementado.]

[Incluya todas las referencias bibliográficas utilizadas en el documento. Deben estar citadas según normas IEEE y gestionadas mediante un gestor bibliográfico como Mendeley o Zotero.]

BIBLIOGRAFÍA

[1] Sophos, "The state of ransomware in education 2024," Sophos, Tech. Rep., 2024. [Online]. Available: https://www.sophos.com/en-us/blog/the-state-of-ransomware-in-education-2024

[2] J. B. Ulven and G. Wangen, "A systematic review of cybersecurity risks in higher education," *Future Internet*, vol. 13, no. 2, p. 39, 2021.

[3] J. Li, W. Xiao, and C. Zhang, "Data security crisis in universities: identification of key factors affecting data breach incidents," *Humanities and Social Sciences Communications*, vol. 10, p. 270, May 2023.

[4] Q. Liu and M. Khalil, "Understanding privacy and data protection issues in learning analytics using a systematic review," *British Journal of Educational Technology*, vol. 54, no. 6, pp. 1715–1747, Nov. 2023.

[5] J. Fernandes, C. Machado, and L. Amaral, "Identifying critical success factors for the general data protection regulation implementation in higher education institutions," *Digital Policy, Regulation and Governance*, vol. 24, no. 4, pp. 355–379, 2022.

[6] Semana, "Los detalles secretos del grave hackeo que sufrió la Universidad Nacional," Apr. 2023. [Online]. Available: https://www.semana.com/nacion/articulo/asi-fue-el-hackeo-del-que-fue-victima-la-universidad-nacional/202335/

[7] CNN Chile, "Hackeo a la Universidad Santa María: datos de estudiantes y académicos fueron vulnerados y publicados en la dark web," Nov. 2024. [Online]. Available: https://www.cnnchile.com/pais/hackeo-universidad-santa-maria-datos-estudiantes-academicos-vulnerados-publicados-dark-web_20241116/

[8] T. D. Zappelini, L.-M. Schippers, and A. P. da Silva, "Personal data of adolescents in higher education: The LGPD and the use of digital media for teaching activities and remote testing," *Revista Direito GV*, vol. 19, p. e2335, 2023.

[9] Y. Arciniegas, “Falla informática en Ecuador: los datos de casi toda la población quedaron expuestos,” France 24, Sep. 2019. [Online]. Available: https://www.france24.com/es/20190917-ecuador-datos-expuestos-informacion-filtracion

[10] Asamblea Nacional del Ecuador, “Ley Orgánica de Protección de Datos Personales,” Registro Oficial Quinto Suplemento N.º 459, Quito, Ecuador, May 2021.

[11] Presidencia de la República del Ecuador, “Reglamento General a la Ley Orgánica de Protección de Datos Personales (Decreto Ejecutivo N.º 904),” Registro Oficial Tercer Suplemento N.º 435, Quito, Ecuador, Nov. 2023.

[12] Superintendencia de Protección de Datos Personales, “Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales,” Resolución N.º SPDP-SPD-2025-0003-R, 29 de abril de 2025. Registro Oficial Cuarto Suplemento N.º 41, 19 de mayo de 2025, Quito, Ecuador, 2025. [Online]. Available: https://spdp.gob.ec/wp-content/uploads/2025/05/03.01.01-SPDP-SPD-2025-0003-R-Guia-Gest-de-Riesg-y-Ev-Imp-signed.pdf

[13] Lexis, “Registro Oficial del día: Superintendencia expide guía para gestión de riesgos y evaluación de impacto en tratamiento de datos personales,” 2025. [Online]. Available: https://www.lexis.com.ec/noticias/registro-oficial-del-dia-superintendencia-expide-guia-para-gestion-de-riesgos-y-evaluacion-de-impacto-en-tratamiento-de-datos-personales

[14] Superintendencia de Protección de Datos Personales, “Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales, Versión 2,” Resolución N.º SPDP-SPD-2026-0012-R. Registro Oficial Suplemento N.º 254, 30 de marzo de 2026, Quito, Ecuador, 2026. [Online]. Available: https://spdp.gob.ec/wp-content/uploads/2026/03/ggrispdp2026v2.pdf

[15] ——, “Norma General sobre el Tratamiento de Datos Personales a Gran Escala,” Resolución N.º SPDP-SPD-2026-0005-R, Registro Oficial Suplemento N.º 231, 25 de febrero de 2026, Quito, Ecuador, 2026.

[16] R. Revelo, “Superintendencia de datos sanciona a LigaPro y FEF por infracciones en el tratamiento de datos personales,” Primicias, Dec. 2025. [Online]. Available: https://www.primicias.ec/deportes/futbol/superintendencia-datos-sanciona-ligapro-fef-infracciones-tratamiento-datos-personales-110763/

[17] ECIJA GPA, “Primeras sanciones por vulneración de datos en Ecuador,” Dec. 2025. [Online]. Available: https://www.ecija.com/actualidad-insights/primeras-sanciones-por-vulneracion-de-datos-en-ecuador/

[18] M. Almeida and P. Mena Mena, “Cero sanciones en Ecuador por una ley de protección de datos personales blandengue,” Primicias, Sep. 2025. [Online]. Available: https://www.primicias.ec/politica/cero-sanciones-ecuador-ley-proteccion-datos-personales-blandengue-104527/

[19] J. A. Álvarez-Carrión and G. P. Hernández-Sotomayor, “Protección de datos personales en plataformas educativas digitales en el sistema de educación superior de Ecuador,” *MQRInvestigar*, vol. 8, no. 3, pp. 5324–5339, 2024.

[20] P. O. Piray Rodríguez, S. W. Parra Molina, J. E. Yaulema Colcha, and J. J. Salazar Briones, “Garantías jurídicas de la privacidad informativa en instituciones de educación superior del Ecuador contemporáneo,” *Universidad y Sociedad*, vol. 18, no. 2, p. e5877, 2026. [Online]. Available: https://rus.ucf.edu.cu/index.php/rus/article/view/5877

[21] F. López-Vasco, M. Angulo-Alvarez, D. I. Sosa Zuñiga, E. Puente Moromenacho, N. Ortiz *et al.*, “Application of ISO/IEC 27,001 in higher education technological institutes: Case-control study,” in *Developments and Advances in Defense and Security (MICRADS 2024)*, ser. Smart Innovation, Systems and Technologies, vol. 423. Singapore: Springer, 2025, pp. 179–189.

[22] M. Deng, K. Wuyts, R. Scandariato, B. Preneel, and W. Joosen, “A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements,” *Requirements Engineering*, vol. 16, no. 1, pp. 3–32, 2011.

[23] F. Bieker, M. Friedewald, M. Hansen, H. Obersteller, and M. Rost, “A process for data protection impact assessment under the European General Data Protection Regulation,” in *Privacy Technologies and Policy (APF 2016)*, ser. Lecture Notes in Computer Science, vol. 9857. Cham: Springer, 2016, pp. 21–37.

[24] K. Vemou and M. Karyda, “Evaluating privacy impact assessment methods: guidelines and best practice,” *Information and Computer Security*, vol. 28, no. 1, pp. 35–53, 2020.

[25] S. Wairimu, L. H. Iwaya, L. Fritsch, and S. Lindskog, “On the evaluation of privacy impact assessment and privacy risk assessment methodologies: A

systematic literature review," *IEEE Access*, vol. 12, pp. 19 625–19 650, Feb. 2024.

[26] L. H. Iwaya, A. S. Alaqra, M. Hansen, and S. Fischer-Hübner, "Privacy impact assessments in the wild: A scoping review," *Array*, vol. 23, p. 100356, Sep. 2024.

[27] S. Wairimu, L. H. Iwaya, L. Fritsch, and S. Lindskog, "Understanding practitioner perspectives on using privacy harm categories for privacy risk assessment," *Journal of Information Security and Applications*, vol. 93, p. 104174, Sep. 2025.

[28] J. Wang, M. Neil, and N. Fenton, "A bayesian network approach for cybersecurity risk assessment implementing and extending the FAIR model," *Computers & Security*, vol. 89, p. 101659, Feb. 2020.

[29] S. Patiño, E. F. Solís, S. G. Yoo, and R. Arroyo, "ICT risk management methodology proposal for governmental entities based on ISO/IEC 27005," in *2018 International Conference on eDemocracy & eGovernment (ICEDEG)*. Ambato, Ecuador: IEEE, 2018, pp. 75–82.

[30] M. E. Gursoy, A. Inan, M. E. Nergiz, and Y. Saygin, "Privacy-preserving learning analytics: Challenges and techniques," *IEEE Transactions on Learning Technologies*, vol. 10, no. 1, pp. 68–81, 2017.

[31] A. Habbabeh, B. Schneider, and P. M. Asprion, "Data privacy assessment: An exemplary case for higher education institutions," *International Journal of Management, Knowledge and Learning*, vol. 8, no. 2, pp. 221–241, 2019. [Online]. Available: https://www.issbs.si/press/ISSN/2232-5697/8_221-241.pdf

[32] E. Vanezi, D. Kouzapas, G. M. Kapitsaki, T. Costi, A. Yeratziotis, C. Mettouris, A. Philippou, and G. A. Papadopoulos, "GDPR compliance in the design of the INFORM e-learning platform: A case study," in *2019 13th International Conference on Research Challenges in Information Science (RCIS)*. Brussels, Belgium: IEEE, May 2019, pp. 1–12.

[33] Y.-S. Tsai, A. Whitelock-Wainwright, and D. Gašević, "The privacy paradox and its implications for learning analytics," in *Proceedings of the 10th International Conference on Learning Analytics & Knowledge (LAK '20)*. Frankfurt, Germany: ACM, Mar. 2020, pp. 230–239.

[34] K. Maguraushe, A. Da Veiga, and N. Martins, "Assessing information privacy awareness, expectations, and confidence of students: Evidence from a diagnostic survey in a developing country's higher education sector," *Journal of Cybersecurity and Privacy*, vol. 6, no. 2, p. 62, Apr. 2026.

[35] C. Guerrero Argote, "Impacto en la privacidad a partir del uso de tecnologías de e-proctoring en la región de Latinoamérica: estudio del caso en universidades de Argentina, Chile y Perú," *Revista Latinoamericana de Economía y Sociedad Digital*, no. 2, 2021.

[36] *Information technology – Security techniques – Guidelines for privacy impact assessment*, International Organization for Standardization Std. ISO/IEC 29 134:2023, May 2023. [Online]. Available: https://www.iso.org/standard/86012.html

[37] Agencia Española de Protección de Datos, "Gestión del riesgo y evaluación de impacto en tratamientos de datos personales," Guía, Madrid, Jun. 2021. [Online]. Available: https://www.aepd.es/guias/gestion-riesgo-y-evaluacion-impacto-en-tratamientos-datos-personales.pdf

[38] K. R. Boeckl and N. B. Lefkovitz, "NIST privacy framework: A tool for improving privacy through enterprise risk management, version 1.0," National Institute of Standards and Technology, Gaithersburg, MD, Cybersecurity White Paper CSWP 01162020, Jan. 2020.

[39] European Union Agency for Network and Information Security, "Recommendations for a methodology of the assessment of severity of personal data breaches," ENISA, Working document v1.0, Dec. 2013. [Online]. Available: https://www.enisa.europa.eu/publications/dbn-severity

[40] Superintendencia de Industria y Comercio, "La SIC presenta una guía para fortalecer la protección de los datos personales en las Instituciones de Educación Superior," Comunicado de prensa, Bogotá, Colombia, Aug. 2026. [Online]. Available: https://sedeelectronica.sic.gov.co/comunicado/la-sic-presenta-una-guia-para-fortalecer-la-proteccion-de-los-datos-personales-en-las-instituciones-de-educacion-superior

[41] *Information security, cybersecurity and privacy protection – Guidance on managing information security risks*, International Organization for Standardization Std. ISO/IEC 27 005:2022, Oct. 2022. [Online]. Available: https://www.iso.org/standard/80585.html

[42] *Risk management – Guidelines*, International Organization for Standardization Std. ISO 31 000:2018, 2018. [Online]. Available: https://www.iso.org/standard/65694.html

[43] *Information security, cybersecurity and privacy protection – Privacy information management systems – Requirements and guidance*, International Organization for Standardization Std. ISO/IEC 27 701:2025, Oct. 2025. [Online]. Available: https://www.iso.org/standard/27701

[44] R. Hernández-Sampieri and C. P. Mendoza Torres, *Metodología de la investigación: las rutas cuantitativa, cualitativa y mixta*. Ciudad de México: McGraw-Hill, 2018.

[45] A. R. Hevner, S. T. March, J. Park, and S. Ram, "Design science in information systems research," *MIS Quarterly*, vol. 28, no. 1, pp. 75–105, 2004.

[46] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, "A design science research methodology for information systems research," *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.

[47] C. Okoli and S. D. Pawlowski, "The Delphi method as a research tool: an example, design considerations and applications," *Information & Management*, vol. 42, no. 1, pp. 15–29, 2004.

[48] G. W. Brier, "Verification of forecasts expressed in terms of probability," *Monthly Weather Review*, vol. 78, no. 1, pp. 1–3, 1950.

[49] *Information security, cybersecurity and privacy protection – Information security controls*, International Organization for Standardization Std. ISO/IEC 27 002:2022, 2022. [Online]. Available: https://www.iso.org/standard/75652.html

GLOSARIO

[Defina los términos técnicos relevantes utilizados en el documento.]

Término o sigla 1 *[Definición técnica breve y clara.]*

Término o sigla 2 *[Definición técnica breve y clara.]*

ANEXO A

LISTA DE VERIFICACIÓN DE REQUISITOS NORMATIVOS

Objetivo: verificar, para el proceso analizado, el cumplimiento de los requisitos de la LOPDP, su Reglamento General y la normativa técnica de la SPDP que inciden en la gestión de riesgos (OE1). **Aplicación:** revisión documental y contraste con la práctica efectiva; para cada requisito se registra la evidencia observada, no solo la existencia de una política escrita. **Escala:** C = cumple; P = cumple parcialmente; N = no cumple; NA = no aplica.

N.º	Requisito	Fundamento	Evidencia esperada	C/P/N/NA
1	El responsable mantiene un inventario o registro de las actividades de tratamiento del proceso.	LOPDP art. 40; guía SPDP (contexto)	RAT actualizado	
2	Cada actividad de tratamiento tiene una base de legitimación identificada y documentada.	LOPDP	Matriz de bases de legitimación	
3	El consentimiento, cuando es la base de legitimación, se solicita de forma diferenciada por finalidad.	LOPDP	Formularios y cláusulas	
4	Se informa al titular sobre las finalidades, los destinatarios, los plazos y el ejercicio de sus derechos.	LOPDP	Aviso de privacidad	
5	Las categorías especiales de datos (salud, discapacidad, adolescentes) se identifican y reciben protección reforzada.	LOPDP art. 25	Clasificación y controles específicos	
6	Existen medidas de seguridad técnicas, organizativas y jurídicas, con verificación y evaluación continua de su eficacia.	LOPDP art. 37	Políticas, registros de revisión	
7	Se aplica una metodología de análisis de riesgos, amenazas y vulnerabilidades adaptada a la naturaleza del tratamiento.	LOPDP arts. 40 y 68 num. 4	Metodología y matriz de riesgos	
8	Se ha determinado si el tratamiento es de gran escala y, en su caso, se ha realizado la evaluación de impacto previa.	LOPDP art. 42; Res. SPDP-SPD-2026-0005-R	Dictamen de gran escala; EIPD	
9	Se ha designado un delegado de protección de datos cuando la normativa lo exige.	Res. SPDP-SPD-2026-0005-R	Acto de designación	
10	Existe un procedimiento para gestionar y notificar vulneraciones a la autoridad en el término legal.	LOPDP art. 43	Procedimiento y registro de incidentes	
11	Los contratos con encargados (pasarela de pagos, nube, LMS, CRM) contienen cláusulas de protección de datos.	LOPDP; normativa SPDP sobre encargados	Contratos y anexos	
12	Las transferencias a proveedores ubicados fuera	LOPDP; normativa SPDP sobre	Evaluación de transferencias	

Nota: los requisitos sin número de artículo se verificarán contra el texto oficial antes de la aplicación definitiva del instrumento.

ANEXO B

GUÍA DE ENTREVISTA SEMIESTRUCTURADA

Objetivo: caracterizar la práctica efectiva de tratamiento de datos personales en cada subproceso de admisión y matrícula (OE1). **Informantes:** responsables (simulados) de Admisiones, Secretaría Académica, Bienestar Estudiantil, Dirección Financiera y Dirección de TI; expertos del panel. **Duración estimada:** 45 a 60 minutos. **Registro:** notas del entrevistador y, con autorización, grabación de audio que se elimina tras la transcripción. Los entrevistados se identifican con códigos (E01, E02, . . .).

Protocolo de inicio

1. Presentar el propósito académico del estudio y el carácter simulado del caso.
2. Confirmar la firma del consentimiento informado (Anexo G) y la autorización de grabación.
3. Recordar que no se solicitarán datos personales de estudiantes ni de aspirantes.

Bloque 1. Finalidades y bases de legitimación

1. ¿Qué datos personales se recolectan en su unidad durante el proceso de admisión y matrícula y con qué finalidad?
2. ¿Cómo se informa al aspirante sobre el uso de sus datos? ¿Se solicita su consentimiento? ¿Para qué finalidades?
3. ¿Se utilizan los datos para fines distintos de la admisión (difusión, marketing, investigación)?

Bloque 2. Categorías especiales y grupos vulnerables

1. ¿Se tratan datos de salud, discapacidad, condición socioeconómica o de menores de edad? ¿En qué subproceso?
2. ¿Qué tratamiento diferenciado reciben esos datos (acceso, almacenamiento, conservación)?

Bloque 3. Sistemas, accesos y terceros

1. ¿En qué sistemas, repositorios o servicios en la nube se almacenan los datos?
2. ¿Cómo se asignan, revisan y retiran los permisos de acceso? ¿Qué ocurre con el personal temporal?
3. ¿Qué proveedores externos acceden a los datos? ¿Existen cláusulas contractuales de protección de datos?

Bloque 4. Conservación y eliminación

1. ¿Cuánto tiempo se conservan los expedientes de aspirantes admitidos y no admitidos?
2. ¿Existe un procedimiento de eliminación o anonimización? ¿Quién lo ejecuta y cómo se registra?

Bloque 5. Incidentes y riesgos

1. ¿Conoce incidentes de seguridad o de exposición de datos ocurridos en el proceso (sin identificar personas)?
2. ¿Qué haría su unidad ante la pérdida o exposición de datos? ¿A quién reportaría y en qué plazo?
3. ¿Cuáles considera que son los tres principales riesgos para los titulares en su subproceso?

Cierre

Agradecer la participación, preguntar si desea agregar algo y explicar el uso que se dará a la información.

ANEXO C

CUESTIONARIO DE MADUREZ EN PROTECCIÓN DE DATOS PERSONALES

Objetivo: establecer la línea base de madurez de la institución en la gestión de datos personales del proceso analizado (fase 0, OE1). **Instrucciones:** para cada enunciado, seleccione el nivel que mejor describe la situación *real* de la institución, no la deseada ni la escrita en una política. El nivel de cada dominio es la mediana de sus enunciados; el nivel global es la mediana de los dominios.

Nivel	Denominación	Descripción
1	Inicial	No existen prácticas definidas; las actividades dependen de iniciativas individuales.
2	Repetible	Existen prácticas informales que se repiten, sin documentación ni responsables formales.
3	Definido	Las prácticas están documentadas, aprobadas y asignadas a responsables.
4	Gestionado	Las prácticas se miden con indicadores y se revisan periódicamente.
5	Optimizado	Las prácticas se mejoran de forma continua a partir de los resultados y de los incidentes.

Dominio	N.º	Enunciado	1	2	3	4	5
Gobernanza	1	Existe una política de protección de datos aprobada por la autoridad institucional.					
	2	Hay un responsable o delegado de protección de datos con funciones definidas.					
	3	La protección de datos se considera en la planificación de nuevos procesos y sistemas.					
Inventario y licitud	4	Se mantiene un RAT actualizado del proceso.					
	5	Cada tratamiento tiene una base de legitimación documentada.					
	6	Los formularios informan al titular y separan las finalidades.					
Gestión de riesgos	7	Se identifican y evalúan los riesgos para los titulares.					
	8	Se determina cuándo se requiere una EIPD.					
	9	Los riesgos tienen responsables, planes de tratamiento y seguimiento.					
Seguridad	10	Los accesos se asignan por función y se revisan periódicamente.					
	11	Los datos sensibles se clasifican, cifran y respaldan.					
	12	Se registran y monitorean los accesos a datos sensibles.					
Terceros	13	Los contratos con encargados incluyen cláusulas de protección de datos.					
	14	Se evalúan las transferencias a proveedores en la nube.					
Ciclo de vida	15	Existen plazos de conservación definidos.					
	16	Los datos se eliminan o anonimizan al vencer el plazo.					
Derechos e incidentes	17	Las solicitudes de los titulares se atienden en plazo y se registran.					
	18	Existe un procedimiento probado de notificación de vulneraciones.					
Cultura	19	El personal recibe capacitación periódica en protección de datos.					
	20	Los incidentes se analizan para mejorar los controles.					

ANEXO D

CUESTIONARIO DELPHI DE ESTIMACIÓN DE RIESGOS

Objetivo: estimar, mediante consenso de expertos, la probabilidad anual y el impacto de cada escenario de riesgo del caso de estudio (OE3 y OE4). **Participantes:** panel de al menos cinco expertos, identificados con códigos. **Procedimiento:** hasta tres rondas anónimas; desde la segunda ronda, cada experto recibe la mediana, el rango intercuartílico (RIC) y los argumentos anonimizados del panel y puede revisar su estimación. Se considera alcanzado el consenso cuando el RIC es igual o menor que 1. Las respuestas se registran en la hoja *Delphi* de la plantilla de matriz (Anexo H).

Escalas: probabilidad anual e impacto sobre el titular según las Tablas 13 y 14 del Capítulo II (1 = muy baja/muy bajo; 5 = muy alta/muy alto).

Código del experto: _____ Ronda: _____ Fecha: _____

Escenario _____	**Dimensión:** C I D Licitud
Descripción del escenario	(comunidad de amenaza, vector, vulnerabilidad, datos y titulares afectados)
Resultado de la ronda anterior	Mediana: _____ RIC: _____ Argumentos del panel:
Probabilidad anual (1–5)	_____
Justificación de la probabilidad	
Impacto sobre el titular (1–5)	_____
Justificación del impacto	
Grado de confianza en la estimación	Bajo Medio Alto

ANEXO E

AFIRMACIONES DE CALIBRACIÓN DE EXPERTOS

Objetivo: medir la calibración de cada experto antes de la primera ronda Delphi mediante el puntaje de Brier (Ecuación 1). **Instrucciones:** indique la probabilidad, entre 0 y 1, de que cada afirmación sea verdadera. No consulte fuentes; responda con su conocimiento actual. Las respuestas se registran en la hoja *Brier* de la plantilla (Anexo H); los resultados reales se revelan al finalizar.

N.º	**Afirmación**	**Probabilidad de que sea verdadera (0–1)**
C01	La LOPDP se publicó en el Registro Oficial en 2021.	
C02	El artículo 43 de la LOPDP fija un término de cinco días para notificar vulneraciones a la autoridad.	
C03	ISO/IEC 27005:2022 es una norma certificable.	
C04	El Reglamento General a la LOPDP se expidió mediante Decreto Ejecutivo N.º 904.	
C05	Según el estudio de Sophos de 2024, más del 60 % de las IES encuestadas sufrió un ataque de *ransomware* en el último año.	
C06	ISO/IEC 27002:2022 agrupa sus controles en cuatro temas.	
C07	ISO/IEC 27002:2022 contiene más de 100 controles.	
C08	El Reglamento General de Protección de Datos europeo es aplicable desde mayo de 2018.	
C09	El marco LINDDUN incluye la categoría de amenaza *spoofing*.	
C10	La Resolución SPDP-SPD-2026-0005-R regula el tratamiento de datos personales a gran escala.	

ANEXO F

INSTRUMENTO DE VALIDACIÓN POR JUICIO DE EXPERTOS

Objetivo: valorar la metodología propuesta y sus productos (OE5). **Instrucciones:** tras revisar el documento metodológico, la plantilla de matriz y el expediente del caso simulado, califique cada criterio en una escala de 1 (totalmente en desacuerdo) a 5 (totalmente de acuerdo) y registre sus observaciones. Se considera validado un criterio cuando la mediana del panel es igual o mayor que 4.

Código del experto: _____ Perfil profesional: _____

Años de experiencia: _____

N.º	Criterio	Enunciado	1	2	3	4	5
V01	Pertinencia	La metodología responde a las obligaciones de análisis de riesgos y evaluación de impacto de la LOPDP.					
V02	Pertinencia	Es adecuada para el contexto de una IES ecuatoriana.					
V03	Coherencia normativa	Sus fases siguen las etapas de la guía de la SPDP.					
V04	Coherencia normativa	Las estimaciones exigen justificación y se refieren a un lapso anual.					
V05	Claridad	Las actividades y productos de cada fase se entienden sin ambigüedad.					
V06	Claridad	Las escalas de probabilidad e impacto son comprensibles y discriminan entre niveles.					
V07	Enfoque en el titular	La valoración del impacto refleja el daño a los titulares y no solo a la institución.					
V08	Suficiencia	La tabla de decisión y los criterios de aceptación tratan adecuadamente los riesgos de baja probabilidad y alto impacto.					
V09	Aplicabilidad	La metodología puede aplicarse con los recursos habituales de una IES.					
V10	Aplicabilidad	La plantilla de matriz es fácil de usar y reutilizable en otros procesos.					
V11	Utilidad	Los resultados permiten priorizar controles y documentar la responsabilidad proactiva.					
V12	Mejora continua	La fase de monitoreo permite mantener la gestión de riesgos actualizada.					

Preguntas abiertas

1. ¿Qué elementos de la metodología considera más valiosos?
2. ¿Qué elementos modificaría, eliminaría o agregaría?
3. ¿Qué obstáculos prevé para su adopción en una IES?

ANEXO G

CONSENTIMIENTO INFORMADO

CONSENTIMIENTO INFORMADO PARA PARTICIPAR EN EL ESTUDIO

Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales

Investigador: Ramón Alejandro Manzaba Castro, estudiante de Ingeniería en Tecnologías de la Información, Universidad Tecnológica Indoamérica. **Tutora:** Ing. Cristina Jiménez, MSc.

Propósito. Usted ha sido invitado a participar como experto en un trabajo de integración curricular cuyo propósito es diseñar y validar una metodología de gestión de riesgos para el tratamiento de datos personales en instituciones de educación superior. El caso de estudio es simulado y no involucra datos personales reales de estudiantes ni de aspirantes.

Participación. Su participación consiste en responder, según corresponda, una entrevista, un cuestionario de calibración, hasta tres rondas de un cuestionario Delphi y un instrumento de validación. El tiempo estimado total es de tres horas, distribuidas en varias semanas.

Datos que se recogerán. Sus respuestas, su perfil profesional y sus años de experiencia. Su nombre no aparecerá en el documento; se le asignará un código (E01, E02, . . .). Si la entrevista se graba, el audio se eliminará después de su transcripción.

Finalidad y conservación. La información se utilizará exclusivamente con fines académicos para este trabajo, se almacenará en medios con acceso restringido y se eliminará al concluir el proceso de titulación, salvo las respuestas anonimizadas que forman parte del documento final.

Voluntariedad y derechos. Su participación es voluntaria y no recibirá compensación. Puede retirarse en cualquier momento sin necesidad de justificarlo y solicitar el acceso, la rectificación o la eliminación de sus respuestas escribiendo al investigador, conforme a la Ley Orgánica de Protección de Datos Personales.

Riesgos y beneficios. La participación no supone riesgos previsibles. El beneficio esperado es contribuir a mejorar la protección de los datos personales en las instituciones de educación superior.

Contacto. ramonalejandromanzaba@gmail.com

He leído la información anterior, he podido hacer preguntas y acepto participar voluntariamente.

Código asignado: _____

Autorizo la grabación de audio de la entrevista: Sí No

Firma del participante: _____

Firma del investigador: _____

Fecha: _____

ANEXO H

PLANTILLA DE MATRIZ DE RIESGOS

La plantilla reutilizable de la matriz de riesgos (OE4) se entrega como archivo de hoja de cálculo `matriz/Plantilla_Matriz_Riesgos_LOPDP.xlsx`, compatible con Microsoft Excel y LibreOffice Calc. Su estructura implementa el diseño de la Sección 2.6. Las celdas de ingreso se distinguen de las celdas con fórmula, y los campos categóricos usan listas desplegables. Los niveles de riesgo se colorean con formato condicional. La Tabla 28 describe sus hojas.

Tabla 28: Hojas de la plantilla de matriz de riesgos.

Hoja	**Contenido**
Instrucciones	Propósito, leyenda de colores, pasos por fase y reglas de la guía de la SPDP.
Matriz	Una fila por escenario y dimensión, con 34 campos agrupados en seis bloques. Calcula el impacto ajustado, el nivel inherente y el residual, la necesidad de EIPD y el criterio de aceptación.
Decisión	Tabla de decisión del nivel de riesgo y criterios de aceptación.
Escalas	Escalas de probabilidad anual, de impacto sobre el titular y sobre el responsable, y criterios agravantes.
Amenazas	Catálogo inicial de doce amenazas del proceso de admisión y matrícula.
Controles	Catálogo de controles candidatos con referencia a ISO/IEC 27002:2022.
Delphi	Registro de rondas con mediana, cuartiles, RIC, consenso y media ponderada por calibración.
Brier	Afirmaciones de calibración, puntaje de Brier y peso de cada experto.
Mapa de calor	Número de escenarios por probabilidad e impacto (inherente y residual) y resumen por nivel.
Listas	Valores de las listas desplegables.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia